



# HISAB PAYMENT GATEWAY

## Technical Proposal, Volume 1

FULL OUTSOURCED DEVELOPMENT OF THE PAYMENT GATEWAY PLATFORM

*June 2026 · Confidential, Not for Distribution*

|                       |                               |                       |                          |
|-----------------------|-------------------------------|-----------------------|--------------------------|
| <b>Proposal Date:</b> | June 12, 2026                 | <b>Revision Date:</b> | 1.0                      |
| <b>Client:</b>        | HISAB Financial Solution S.C. | <b>Project:</b>       | Payment Gateway Platform |

*This is Volume 1, the Technical Proposal, in response to the HISAB Terms of Reference for Payment Gateway Development, Version 1.0 (June 2026). It sets out the methodology, system architecture, technology stack, regulatory strategy, integration plan, security plan, testing strategy, project plan, risks, and team. Figures presented here support evaluation and do not constitute a contractual commitment; the binding reference is the project agreement.*

# Table of Contents

|                                                            |           |
|------------------------------------------------------------|-----------|
| <b>1. Executive Summary</b>                                | <b>4</b>  |
| <b>2. Technical Approach and Methodology</b>               | <b>6</b>  |
| 2.1 Engagement Model: Two Tracks, One Critical Path        | 6         |
| 2.2 Software Process Model                                 | 6         |
| 2.3 Requirements Engineering                               | 7         |
| 2.4 Domain-Driven Decomposition                            | 7         |
| 2.5 Regulatory Methodology (Track A)                       | 7         |
| <b>3. System Architecture Proposal</b>                     | <b>9</b>  |
| 3.1 Architectural Principles                               | 9         |
| 3.2 Logical Architecture: Bounded Contexts                 | 10        |
| 3.3 The Transaction Lifecycle as a Persisted State Machine | 12        |
| 3.4 Data Architecture                                      | 14        |
| 3.5 Deployment Architecture                                | 17        |
| 3.5.1 Availability Arithmetic for the 99.9% SLA            | 19        |
| 3.6 Performance Engineering for 500 TPS / p95 < 200 ms     | 19        |
| 3.6.1 Quantitative Basis for the Performance Targets       | 20        |
| 3.7 Architecture Governance                                | 21        |
| 3.8 Architecture Figures (SADD Preview)                    | 21        |
| <b>4. Technology Stack</b>                                 | <b>26</b> |
| 4.1 Proposed Stack                                         | 26        |
| 4.2 Stack Risk Posture                                     | 27        |
| 4.3 Data Residency and Hosting                             | 28        |
| <b>5. Regulatory Strategy</b>                              | <b>29</b> |
| 5.1 Strategy Overview                                      | 29        |
| 5.2 NBE Licensing Approach                                 | 29        |
| 5.3 AML/CFT Framework                                      | 33        |
| 5.4 Compliance Management                                  | 34        |
| 5.5 Roles and Accountabilities                             | 36        |
| 5.7 Key Assumptions                                        | 37        |

## Email

contact@sydek.dev

## Phone

+251 912983759  
+251 911971885  
+251 712785587

## Location

Kebede Haile Building,  
3rd Floor, Office 302,  
Dembel, Addis Ababa,  
Ethiopia

|                                                     |           |
|-----------------------------------------------------|-----------|
| <b>6. Integration Plan, Ethiopian Payment Rails</b> | <b>39</b> |
| 6.1 Integration Architecture                        | 39        |
| 6.2 Rail-by-Rail Approach and Sequencing            | 40        |
| 6.3 Integration Method per Rail                     | 42        |
| 6.4 Dependencies and De-risking                     | 42        |
| <b>7. Security Plan</b>                             | <b>43</b> |
| 7.1 Security Engineering Framework                  | 43        |
| 7.2 Threat Modeling                                 | 44        |
| 7.3 Data Protection Mechanisms                      | 44        |
| 7.4 Access Control                                  | 44        |
| 7.5 Perimeter and Runtime Defense                   | 45        |
| 7.6 Secure SDLC and Assurance                       | 45        |
| 7.7 Incident Response and Resilience                | 45        |
| <b>8. Testing and Quality Assurance Strategy</b>    | <b>46</b> |
| 8.1 Verification Philosophy                         | 46        |
| 8.2 Correctness of the Money Path                   | 46        |
| 8.3 Integration and Contract Testing                | 46        |
| 8.4 Performance and Load Testing                    | 47        |
| 8.5 Security Testing                                | 47        |
| 8.6 Resilience, DR, and Operational Acceptance      | 47        |
| 8.7 UAT and Pilot                                   | 48        |
| 9.1 Phase Plan                                      | 49        |
| 9.2 Critical Path and Scheduling Logic              | 50        |
| <b>10. Risk Register</b>                            | <b>52</b> |
| <b>11. Team Structure</b>                           | <b>54</b> |
| <b>12. Engineering and Regulatory References</b>    | <b>55</b> |
| 12.1 Engineering Literature                         | 55        |
| 12.2 Standards                                      | 56        |
| 12.3 Ethiopian Legal and Regulatory Instruments     | 56        |

**Email**

[contact@sydek.dev](mailto:contact@sydek.dev)

**Phone**

+251 912983759  
+251 911971885  
+251 712785587

**Location**

Kebede Haile Building,  
3rd Floor, Office 302,  
Dembel, Addis Ababa,  
Ethiopia

# 1. Executive Summary

HISAB Financial Solution Share Company seeks a single accountable partner to take a payment gateway aggregator from regulatory whiteboard to licensed, production-grade national infrastructure within twelve months. We have read the Terms of Reference as what it actually is: not a software project with a compliance appendix, but the construction of a regulated, data-intensive financial system in which the **regulatory track (Track A)** and the **technical track (Track B)** are mutually constraining.

The National Bank of Ethiopia's (NBE) Payment System Operator licensing process under Directive No. ONPS/02/2020 culminates in a supervised pilot and on-site inspection of the operational platform itself, which means the architecture, security posture, and operational evidence produced by Track B are themselves regulatory deliverables for Track A. Our proposal is organized around that interdependency.

Our engineering approach is deliberately conservative where the literature tells us payment systems fail, and aggressively modern where the literature tells us speed is safe. Three design commitments anchor the platform:

The ledger is the system of record, and it is append-only. Following the data architecture principles consolidated in Kleppmann's Designing Data-Intensive Applications, all money movement is recorded as immutable, double-entry journal events; every balance, report, settlement file, and dashboard is derived data that can be rebuilt and independently verified. Reconciliation ceases to be a nightly fire drill and becomes a continuous invariant check (debits equal credits; internal state equals rail-confirmed state).

Failure is a first-class design input. Ethiopian payment rails (EthSwitch, Telebirr, CBE Birr, M-PESA, bilateral bank APIs) will time out, return ambiguous states, and change behavior without notice. We design for this using the stability patterns catalogued in Nygard's Release It! (timeouts, circuit breakers, bulkheads, idempotent retries) and Helland's idempotence discipline, so that a degraded rail degrades one route, never the platform.

Security is an end-to-end property, not a module. Per Anderson's Security Engineering, we treat security as the interaction of policy, mechanism, assurance, and incentives: tokenization and

## Email

[contact@sydek.dev](mailto:contact@sydek.dev)

## Phone

+251 912983759  
+251 911971885  
+251 712785587

## Location

Kebede Haile Building,  
3rd Floor, Office 302,  
Dembel, Addis Ababa,  
Ethiopia

HSM-backed key management shrink the PCI-DSS scope; STRIDE threat modeling is performed per service; and the Secure SDLC produces the assurance evidence that INSA certification and NBE inspection will demand.

On delivery, we follow the incremental, plan-driven hybrid that Sommerville's Software Engineering recommends for critical systems: architecture and interfaces are stabilized early under formal review gates, while feature delivery proceeds in two-week increments with continuous integration, the practice profile empirically associated with both higher throughput and higher stability (Forsgren, Humble, and Kim, Accelerate). Performance is engineered, not hoped for: we commit to the TOR targets of 500 TPS sustained (scalable to 2,000 TPS) at p95 latency under 200 ms, validated by a capacity model (Little's Law, Universal Scalability Law) and load tests designed to avoid the coordinated-omission measurement errors described by Gregg's Systems Performance.

On the regulatory track, we will deliver the complete NBE license application dossier within two months, including all six mandated policy manuals, the AML/CFT framework aligned with the FATF Recommendations and Ethiopia's AML/CFT regime, and a data protection package compliant with the Personal Data Protection Proclamation No. 1321/2024. We will then act as HISAB's regulatory liaison through document review, pilot testing, and on-site inspection to the letter of commercialization.

The remainder of this volume presents our methodology (Section 2), system architecture (Section 3), technology stack (Section 4), regulatory strategy (Section 5), integration plan (Section 6), security plan (Section 7), testing strategy (Section 8), project plan (Section 9), risk register (Section 10), team structure (Section 11), and relevant experience (Section 12). All intellectual property vests exclusively with HISAB upon final payment, per TOR Sections 6.4 and 11.4.

#### **Email**

[contact@sydek.dev](mailto:contact@sydek.dev)

#### **Phone**

+251 912983759  
+251 911971885  
+251 712785587

#### **Location**

Kebede Haile Building,  
3rd Floor, Office 302,  
Dembel, Addis Ababa,  
Ethiopia

## 2. Technical Approach and Methodology

### 2.1 Engagement Model: Two Tracks, One Critical Path

Track A (Regulatory) and Track B (Technical) run in parallel but share a critical path: NBE's licensing process for payment system operators requires demonstration of the actual system, a supervised pilot, security evidence, and on-site readiness inspection precede the commercialization letter. We therefore manage both tracks against a single integrated plan with shared milestones, a joint RAID log, and one accountable Engagement Director. Each NBE-facing artifact (e.g., the cybersecurity policy, the business continuity plan) is jointly owned by a compliance author and the engineer who must make it true in production. This eliminates the most common failure mode in licensed-platform programs: compliance documents that describe a system that was never built.

### 2.2 Software Process Model

Sommerville's treatment of critical-systems engineering (Software Engineering, 10th ed., Pearson) is unambiguous: for systems where failure has financial and regulatory consequences, requirements for safety, security, and dependability must be specified and verified with plan-driven rigor, while functional delivery benefits from incremental development. We therefore adopt a hybrid:

**Plan-driven backbone.** The System Architecture Design Document (SADD), Technical Requirements Specification (TRS), interface contracts for every payment rail, the security architecture, and the data model are produced in Phase 1, formally reviewed with HISAB, baselined, and changed only through change control. These are the elements where late change is most expensive.

**Incremental delivery within the baseline.** Development proceeds in two-week increments organized around vertical slices (e.g., "end-to-end Telebirr payment with webhook confirmation"), each producing demonstrable, tested software. Trunk-based development with continuous integration, automated test gates, and short-lived branches follows the capabilities shown in Accelerate to predict both delivery tempo and change-failure rate.

#### Email

[contact@sydek.dev](mailto:contact@sydek.dev)

#### Phone

+251 912983759  
+251 911971885  
+251 712785587

#### Location

Kebede Haile Building,  
3rd Floor, Office 302,  
Dembel, Addis Ababa,  
Ethiopia

Hardening increments. Every phase ends with a hardening increment dedicated to non-functional requirements: load, failover, security regression, and operational rehearsal. Non-functional work is scheduled, not residual.

## 2.3 Requirements Engineering

Phase 1 opens with a structured discovery workshop series with HISAB stakeholders covering business rules (fee models, settlement cycles, merchant tiers), regulatory constraints, and rail-specific behavior. Requirements are captured in the TRS in three classes, functional, quality (performance, availability, recoverability per TOR Section 6.2), and compliance (traceable to specific NBE directive articles, PCI-DSS requirements, and Proclamation 1321/2024 obligations). Every requirement carries a verification method (test, inspection, analysis, or demonstration), creating the requirements-to-evidence traceability matrix that both UAT sign-off and NBE inspection will consume.

## 2.4 Domain-Driven Decomposition

We decompose the platform using domain-driven design (Evans) rather than by technical layer. Payment processing, merchant lifecycle, settlement and ledger, risk and compliance, rail integration, notification, and reporting are distinct bounded contexts with explicit, versioned contracts between them, the precondition for the independently deployable services that Newman's Building Microservices warns are otherwise a distributed monolith. Each external rail is isolated behind an anti-corruption layer so that Telebirr's API idioms never leak into the core payment engine.

## 2.5 Regulatory Methodology (Track A)

Track A follows a four-stage method: (1) Landscape mapping: a clause-level analysis of the National Payment System Proclamation No. 718/2011 (as amended by Proclamation No. 1282/2023), Directive ONPS/02/2020 (as amended, including ONPS/04/2021) and all secondary obligations (data protection, INSA certification, AML/CFT registration), delivered as the Regulatory Roadmap with fees, authorities, and dependencies. (2) Dossier engineering: the license application is built as a controlled document set with a completeness checklist derived from NBE's published applicant guide, internal quality review, and Amharic translations where required. (3) Active liaison: a named Regulatory Lead manages all NBE correspondence with a 5-working-day internal SLA on query responses, and prepares HISAB for

### Email

[contact@sydek.dev](mailto:contact@sydek.dev)

### Phone

+251 912983759  
+251 911971885  
+251 712785587

### Location

Kebede Haile Building,  
3rd Floor, Office 302,  
Dembel, Addis Ababa,  
Ethiopia

presentations, the supervised pilot, and on-site inspection. (4) Operationalization: reporting templates, the compliance calendar, and automated statutory report generation are built into the platform itself (Section 3.10), so post-license compliance is a system feature, not a manual process.

## ***2.6 Quality Management and Governance***

We operate the governance cadence specified in TOR Section 13 (monthly Steering Committee, weekly technical working group, bi-weekly regulatory call) supplemented by: definition-of-done enforcement in CI (code review, tests, static analysis, security scan); weekly written status against the milestone plan; and formal phase-gate reviews with entry/exit criteria at each payment milestone. Metrics reported monthly include deployment frequency, lead time, change-failure rate, defect escape rate, and test coverage on the money path (target: 100% branch coverage on ledger and settlement arithmetic).

### **Email**

[contact@sydek.dev](mailto:contact@sydek.dev)

### **Phone**

+251 912983759  
+251 911971885  
+251 712785587

### **Location**

Kebede Haile Building,  
3rd Floor, Office 302,  
Dembel, Addis Ababa,  
Ethiopia

## 3. System Architecture Proposal

### 3.1 Architectural Principles

The architecture is derived from five principles, each traceable to established systems literature and to a specific TOR requirement:

**P1: Immutable financial truth (Kleppmann, ch. 11-12).** All money movement is recorded as append-only, double-entry journal entries. Mutable "current state" (balances, transaction status views, dashboards, settlement files) is derived from the journal and event log and can be rebuilt deterministically. This makes audit trails (TOR 3.2.6) structural rather than bolted on, and makes the  $\geq 99.95\%$  reconciliation accuracy target verifiable by construction.

**P2: Exactly-once effects over exactly-once delivery (Helland; Kleppmann ch. 8).** Networks deliver messages at-least-once or not at all; the platform therefore guarantees that retries are safe rather than pretending they will not happen. Every state-changing API requires a client idempotency key; every rail adapter call is wrapped in an idempotent request journal; every consumed event is deduplicated by event ID.

**P3: Stability patterns at every integration boundary (Nygard).** Each rail adapter enforces explicit timeouts, circuit breakers with half-open probing, bounded retry budgets with exponential backoff and jitter, and bulkhead-isolated connection/thread pools. A slow Telebirr cannot exhaust resources needed by EthSwitch traffic.

**P4: Asynchronous core, synchronous edge.** Merchant-facing APIs respond fast with authoritative status; long-running rail interactions, settlement, notification, and reporting flow through the event backbone (Kafka), applying the messaging patterns of Hohpe and Woolf (transactional outbox, competing consumers, dead-letter channels). This is what makes 500→2,000 TPS scalability a configuration change, not a redesign.

**P5: Security and compliance as architecture (Anderson).** Sensitive payment data is tokenized at the perimeter and confined to a small, HSM-backed cardholder-data zone; all other services operate on tokens. The PCI-DSS and NBE inspection scope is thereby minimized by design (Section 7).

#### Email

[contact@sydek.dev](mailto:contact@sydek.dev)

#### Phone

+251 912983759  
+251 911971885  
+251 712785587

#### Location

Kebede Haile Building,  
3rd Floor, Office 302,  
Dembel, Addis Ababa,  
Ethiopia

## 3.2 Logical Architecture: Bounded Contexts

The platform's logical architecture is shown in Figure 1; the table below summarizes each bounded context.

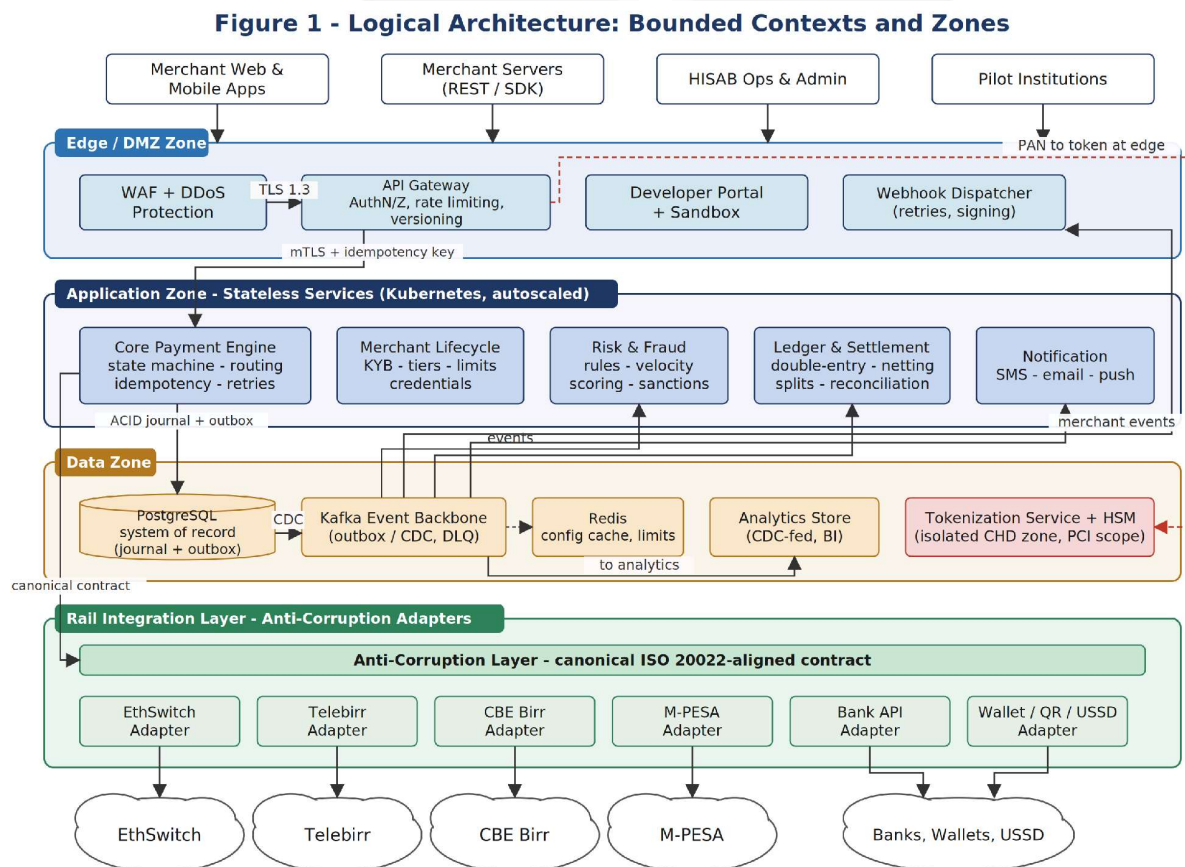


Figure 1. Logical Architecture: bounded contexts across Edge/DMZ, Application, Data, and Rail Integration zones, with the isolated tokenization/CHD zone.

| Bounded Context              | Responsibility                                                                                 | Key TOR Sections |
|------------------------------|------------------------------------------------------------------------------------------------|------------------|
| API Gateway & Developer Edge | AuthN/Z, rate limiting, throttling, API versioning, webhook delivery, developer portal/sandbox | 3.2.5            |

| Bounded Context        | Responsibility                                                                                                       | Key TOR Sections |
|------------------------|----------------------------------------------------------------------------------------------------------------------|------------------|
| Core Payment Engine    | Transaction lifecycle state machine, routing rules, idempotency, retries/fallback, status tracking                   | 3.2.2            |
| Rail Integration Layer | One adapter per rail behind an anti-corruption layer; canonical ISO 20022-aligned internal message model             | 3.2.3            |
| Ledger & Settlement    | Double-entry journal, fee computation, net/gross settlement, multi-party splits, reconciliation, exception workflows | 3.2.6            |
| Merchant Lifecycle     | Onboarding portal, KYB workflows, tiering, limits, API credential provisioning, sandbox certification                | 3.2.4            |
| Risk & Compliance      | Rules engine, velocity controls, scoring, sanctions screening, AML monitoring, SAR/case management                   | 3.1.4, 3.2.7     |
| Notification           | SMS/email/push templates, webhook retry infrastructure, Ethiopian SMS aggregator integration                         | 3.2.10           |
| Reporting & Analytics  | Operational reports, NCM, regulatory reports, dashboard builder, warehouse connectivity                              | 3.1.6, 3.2.11    |

#### Email

[contact@sydek.dev](mailto:contact@sydek.dev)

#### Phone

+251 912983759  
+251 911971885  
+251 712785587

#### Location

Kebede Haile Building,  
3rd Floor, Office 302,  
Dembel, Addis Ababa,  
Ethiopia

| Bounded Context  | Responsibility                                                             | Key TOR Sections |
|------------------|----------------------------------------------------------------------------|------------------|
| Identity & Admin | RBAC/least privilege, MFA, admin and merchant dashboards, audit log viewer | 3.2.8, 3.2.9     |

### 3.3 The Transaction Lifecycle as a Persisted State Machine

The complete lifecycle state machine is diagrammed in Figure 3, and the end-to-end message flow for a representative wallet payment in Figure 5 (Section 3.8).

#### Email

[contact@sydek.dev](mailto:contact@sydek.dev)

#### Phone

+251 912983759  
+251 911971885  
+251 712785587

#### Location

Kebede Haile Building,  
3rd Floor, Office 302,  
Dembel, Addis Ababa,  
Ethiopia

**Figure 3 - Transaction Lifecycle: Persisted State Machine**

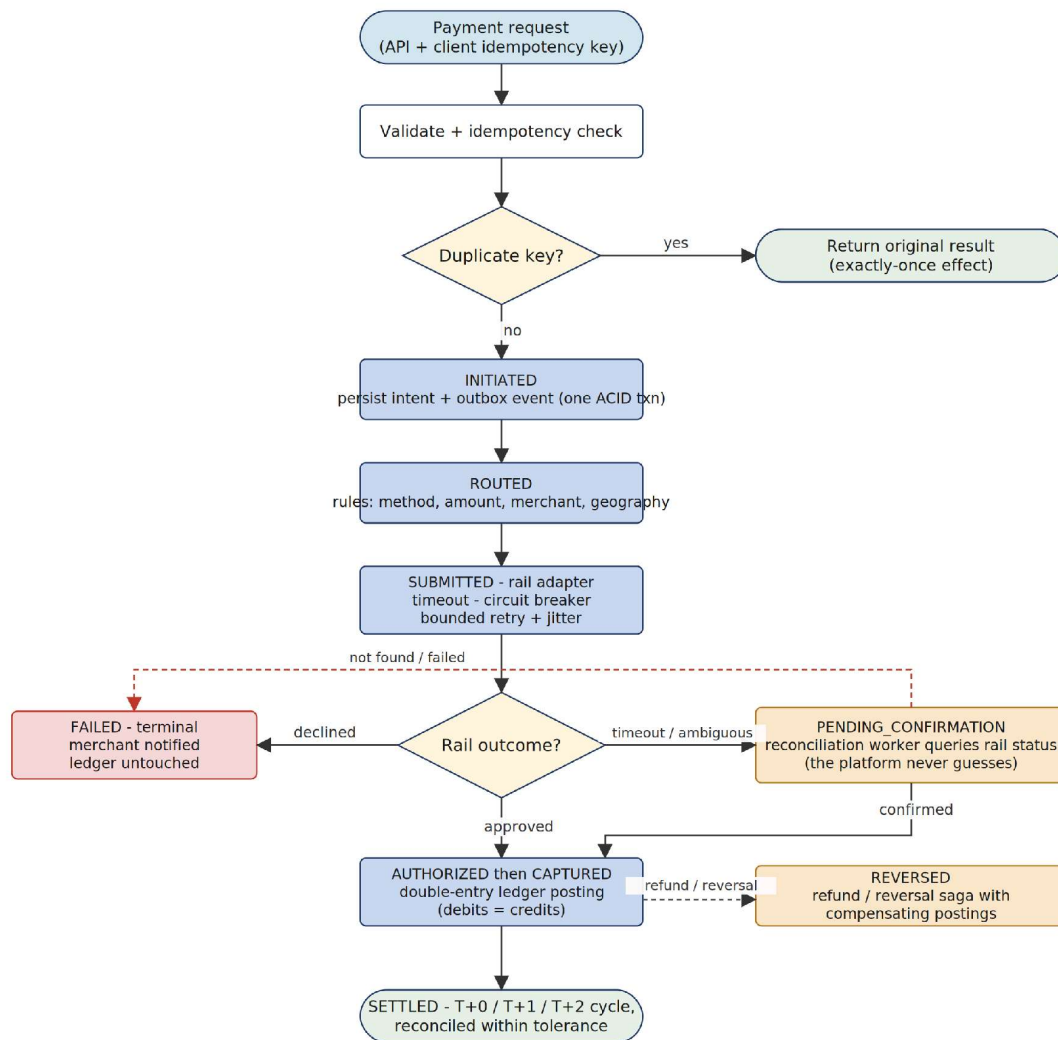


Figure 3. Transaction Lifecycle as a persisted state machine, including the PENDING\_CONFIRMATION resolution path (the platform never guesses outcomes).

Per TOR 3.2.2, the transaction lifecycle (initiation → authorization → capture → settlement → reversal) is implemented as an explicit, persisted finite state machine. Every transition is an event written atomically with its business data in PostgreSQL and published to Kafka via the transactional outbox pattern, eliminating dual-write inconsistency between the database and the event stream

#### Email

contact@sydek.dev

#### Phone

+251 912983759  
+251 911971885  
+251 712785587

#### Location

Kebede Haile Building,  
3rd Floor, Office 302,  
Dembel, Addis Ababa,  
Ethiopia

(Kleppmann ch. 11). Ambiguous rail outcomes (timeout after submission) move transactions to a PENDING\_CONFIRMATION state owned by a reconciliation worker that resolves truth via rail status queries, never by guessing. Distributed operations that span contexts (e.g., capture + ledger posting + notification) are coordinated as sagas with compensating actions rather than two-phase commit, which the literature and operational experience both reject for high-throughput payment paths.

**Figure 10 - Transactional Outbox and Exactly-Once Effects**

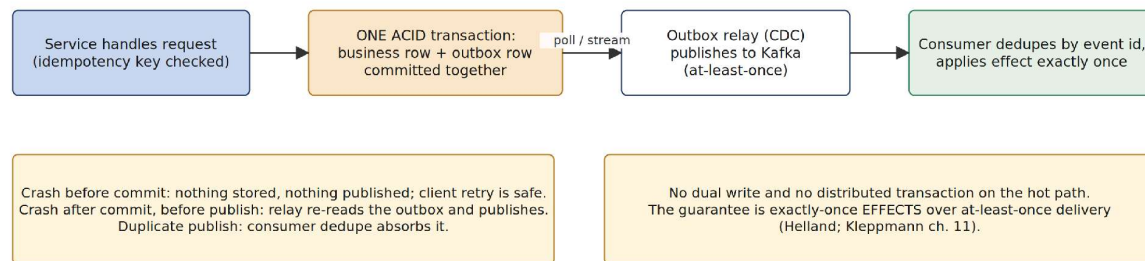


Figure 10. Transactional outbox: business state and the outgoing event commit in one ACID transaction; consumers dedupe by event id, yielding exactly-once effects over at-least-once delivery (Helland).

### 3.4 Data Architecture

System of record: PostgreSQL with synchronous replication to a standby; transaction and journal tables range-partitioned by month for predictable query latency and online archival. All monetary amounts are stored as integer minor units (santim) with explicit currency, floating point is prohibited on the money path.

Ledger: strict double-entry: every posting has balancing debit and credit legs; the invariant  $\text{SUM}(\text{debits}) = \text{SUM}(\text{credits})$  is enforced transactionally and re-verified continuously by an independent checker job, the "end-to-end correctness check on derived data" Kleppmann recommends for systems that cannot tolerate silent corruption.

Event backbone: Kafka topics per context with schema-registry-governed Avro/JSON contracts; consumer groups for settlement, risk, notification, analytics. Dead-letter topics with operator tooling for poison messages.

#### Email

contact@sydek.dev

#### Phone

+251 912983759  
+251 911971885  
+251 712785587

#### Location

Kebede Haile Building,  
3rd Floor, Office 302,  
Dembel, Addis Ababa,  
Ethiopia

Caching: Redis for routing rules, merchant configuration, rate-limit counters, and idempotency-key lookups, with explicit TTL and cache-aside invalidation driven by change events; the cache is never the source of truth.

Analytics: CDC stream from PostgreSQL/Kafka into a columnar analytics store feeding the reporting module and external BI connectivity (TOR 3.2.11), keeping OLAP load off the transactional path.

Sizing arithmetic: at a sustained average of 150 TPS (peak 500), daily volume is  $150 \times 86,400 \approx 13.0$  million transactions; at roughly 2 KB per transaction across journal rows, ledger legs, and indexes this is  $\approx 26$  GB/day, or  $\approx 0.8$  TB per monthly partition. Monthly range partitioning keeps the working set and B-tree depth bounded (3 to 4 levels) as data accumulates, which is what holds the  $\leq 20$  ms persistence budget at year-2 volumes; partitions past the statutory retention window detach to archive without locking the hot path.

Netting arithmetic: with  $m$  transactions per day across  $n$  settlement counterparties, gross settlement moves  $m$  payments while net settlement moves at most  $n$ , where each net position  $P(i) = \sum \text{inflows}(i) - \sum \text{outflows}(i)$  and  $\sum P(i) = 0$  by construction. That conservation identity is the same invariant the double-entry checker verifies continuously, so settlement files are probably consistent with the ledger rather than reconciled to it after the fact.

**Figure 8 - PostgreSQL High Availability Cluster**

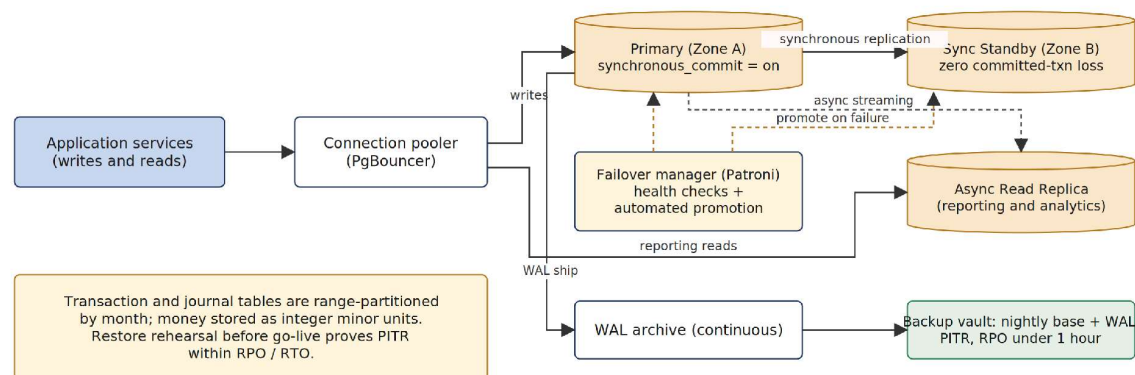


Figure 8. PostgreSQL high availability cluster: synchronous standby for zero committed-transaction loss, async read replica for reporting, automated promotion, continuous WAL archiving with PITR.

## Email

contact@sydek.dev

## Phone

+251 912983759  
+251 911971885  
+251 712785587

## Location

Kebede Haile Building,  
3rd Floor, Office 302,  
Dembel, Addis Ababa,  
Ethiopia

  
sydek.dev

**Figure 9 - Kafka Cluster: Partitions, Replication, Consumer Groups**

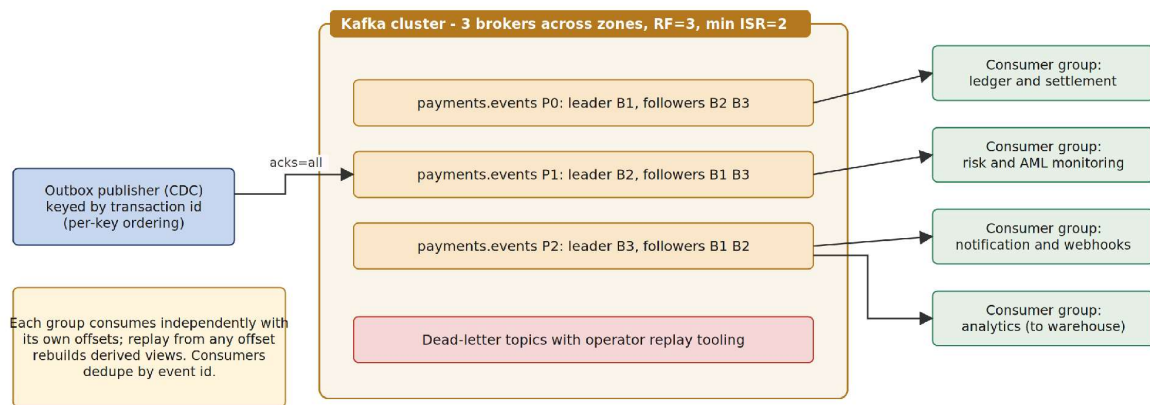
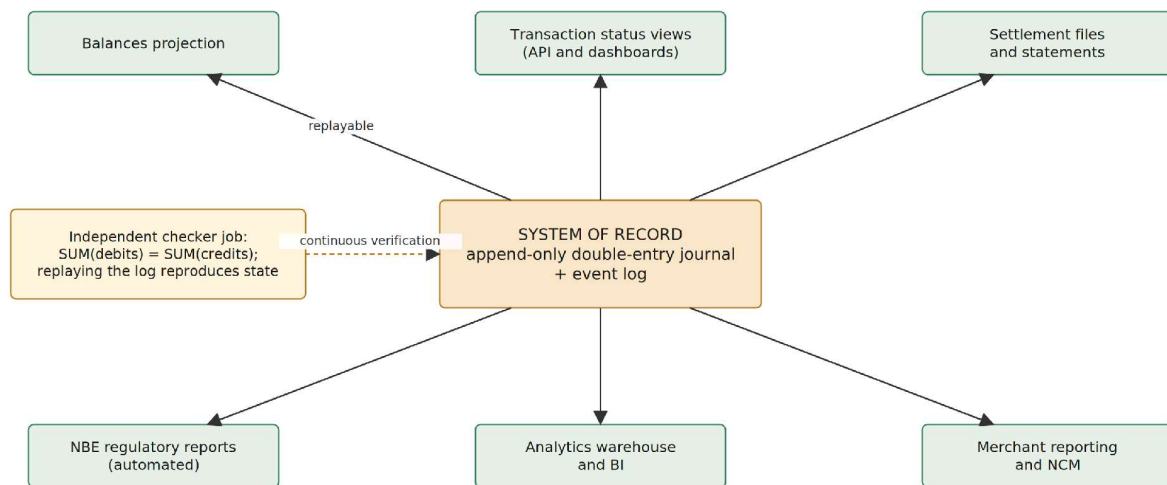


Figure 9. Kafka cluster: partition leadership spread across three brokers (RF=3, min ISR=2, acks=all), independent consumer groups, dead-letter topics with replay tooling (Kleppmann ch. 11).

**Figure 11 - Derived Data and the CQRS Read Path**



Every view is derived data: rebuildable, disposable, independently verifiable (Kleppmann ch. 11-12). Reconciliation is a continuous invariant check, not a nightly batch.

Figure 11. Derived data and the CQRS read path: every view is rebuildable from the append-only journal and event log, with an independent checker continuously verifying ledger invariants (Kleppmann ch. 12).

## Email

contact@sydek.dev

## Phone

+251 912983759  
+251 911971885  
+251 712785587

## Location

Kebede Haile Building,  
3rd Floor, Office 302,  
Dembel, Addis Ababa,  
Ethiopia

### 3.5 Deployment Architecture

The deployment and network topology is shown in Figure 2.

**Figure 2 - Deployment & Network Topology (dual availability zone, in-country)**

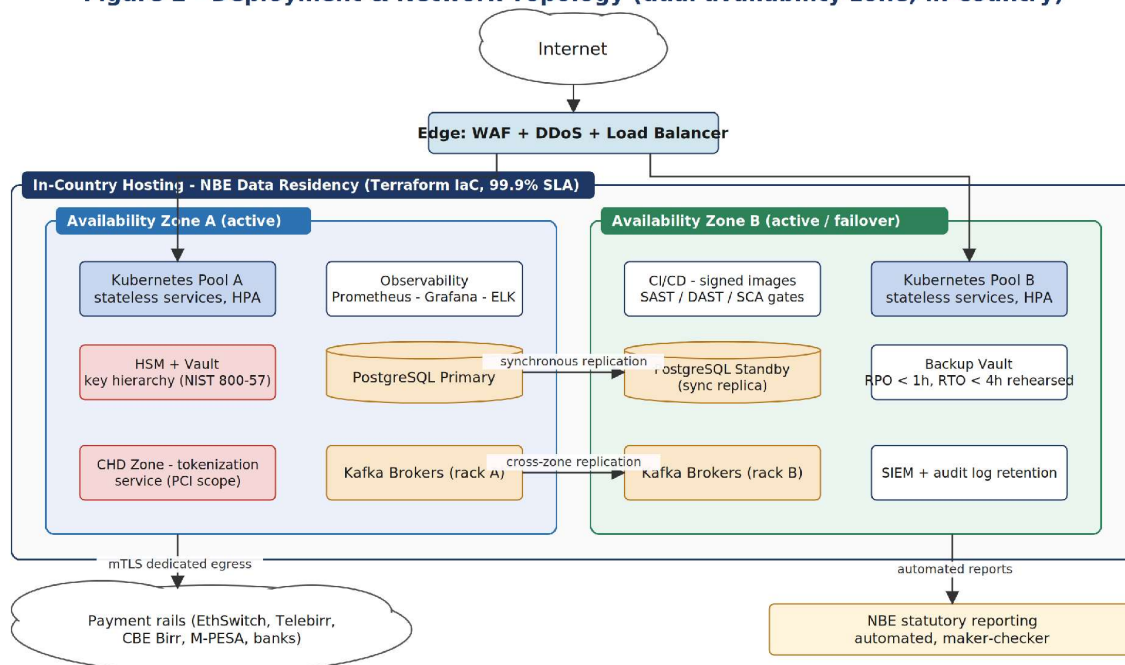


Figure 2. Deployment & Network Topology: dual availability zones in-country, PostgreSQL synchronous replication, Kafka cross-zone replication, HSM/Vault, CI/CD gates, RPO < 1h / RTO < 4h backup.

The platform deploys as containerized services on Kubernetes across a minimum of two availability zones in an NBE-data-residency-compliant environment in Ethiopia (in-country cloud or HISAB-designated data centers; Section 4.3), with a DMZ-segmented network topology: edge zone (WAF, API gateway), application zone (stateless services, horizontally autoscaled), data zone (PostgreSQL, Kafka, Redis, HSM), and a separately firewalled cardholder-data zone. Infrastructure is fully expressed as Terraform code; environments (dev, test, UAT/sandbox, staging, production) are reproducible from the repository. Multi-zone failover, backup/restore with RPO < 1 hour and RTO < 4 hours, and 99.9% availability are designed and rehearsed per Section 8.6, applying SRE error-budget discipline (Beyer et al.) to the uptime SLA.

#### Email

contact@sydek.dev

#### Phone

+251 912983759  
+251 911971885  
+251 712785587

#### Location

Kebede Haile Building,  
3rd Floor, Office 302,  
Dembel, Addis Ababa,  
Ethiopia

**Figure 6 - Kubernetes Cluster Structure (dual-zone worker pools)**

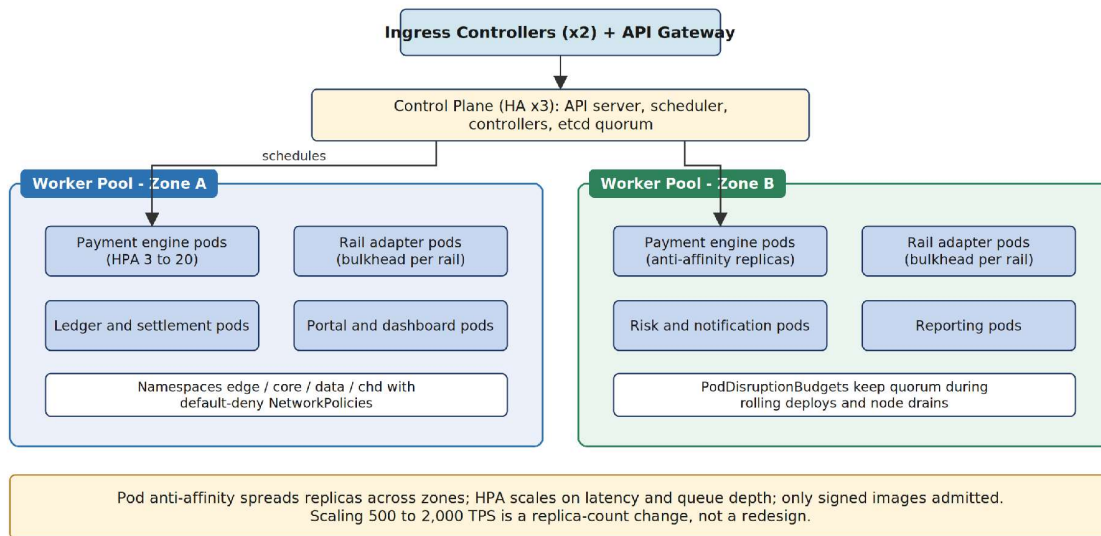


Figure 6. Kubernetes cluster structure: dual-zone worker pools, HPA, pod anti-affinity, namespace isolation with default-deny network policies.

**Figure 7 - High Availability and Failover Scenarios**

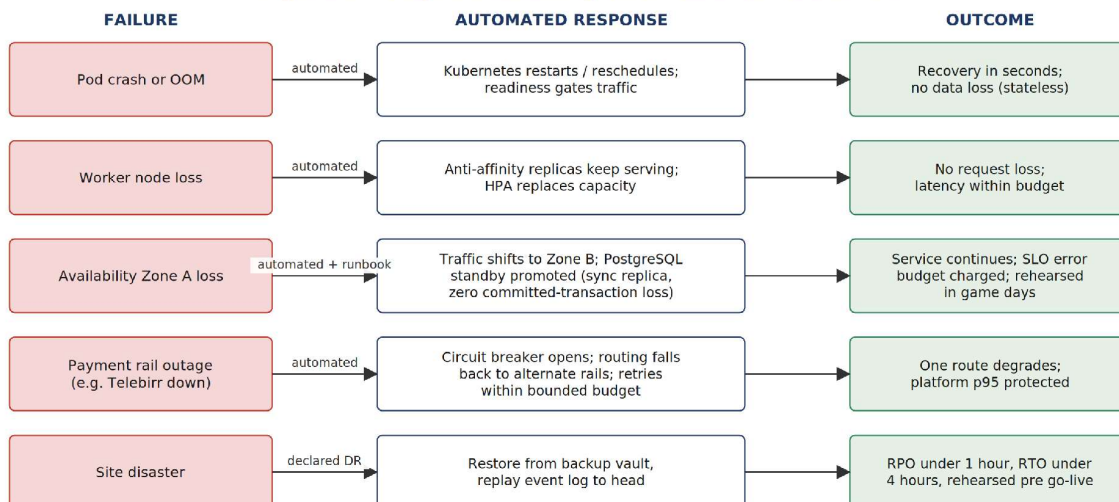


Figure 7. High availability and failover scenarios: each failure mode maps to an automated response and a bounded outcome, rehearsed in game days (Beyer et al.; Nygard).

## Email

contact@sydek.dev

## Phone

+251 912983759  
+251 911971885  
+251 712785587

## Location

Kebede Haile Building,  
3rd Floor, Office 302,  
Dembel, Addis Ababa,  
Ethiopia

### 3.5.1 Availability Arithmetic for the 99.9% SLA

The 99.9% target is treated as a computed property, not an aspiration. A 99.9% monthly SLA allows at most  $0.001 \times 30 \times 24 \times 60 \approx 43.2$  minutes of downtime per 30-day month (8.76 hours per year). The platform is a serial chain of tiers, and the availability of a serial chain composes multiplicatively:  $A(\text{system}) = A(\text{edge}) \times A(\text{app}) \times A(\text{data})$ . Each tier is therefore built from zone-redundant pairs, for which  $A(\text{pair}) = 1 - (1 - A(\text{unit}))^2$ : a single node at 99.5% becomes  $1 - (0.005)^2 = 99.9975\%$  as a redundant pair. The composed chain  $0.99995 \times 0.9999 \times 0.9995 \approx 0.99935$  clears the SLA with margin even before excluding planned maintenance. The remaining 0.1% is managed as an explicit SRE error budget (Beyer et al.): roughly 43 minutes per month deliberately spent on releases and failover game days, with releases frozen when the budget is exhausted.

### 3.6 Performance Engineering for 500 TPS / p95 < 200 ms

We treat the TOR performance targets as an engineering budget, allocated and verified, in the method of Gregg's Systems Performance. A Little's Law sizing model ( $N = X \times R$ : at 500 TPS and 200 ms residence, ~100 requests are concurrently in flight platform-wide) drives initial pool, partition, and replica sizing, with headroom for the 2,000 TPS scale-out. The synchronous hot path is kept minimal (authenticate, validate, persist intent, route) with all fan-out (notifications, analytics, risk enrichment beyond inline rules) asynchronous. A latency budget allocates the 200 ms p95 across gateway ( $\leq 10$  ms), engine ( $\leq 30$  ms), persistence ( $\leq 20$  ms), and rail adapter envelope, with the remainder as buffer; each component budget is asserted in performance tests. Scalability limits are characterized against the Universal Scalability Law to identify contention and coherence costs before they surprise us in production; backpressure (bounded queues, load shedding with explicit 429/503 semantics) protects latency under overload rather than letting queues grow unboundedly.

#### Email

[contact@sydek.dev](mailto:contact@sydek.dev)

#### Phone

+251 912983759  
+251 911971885  
+251 712785587

#### Location

Kebede Haile Building,  
3rd Floor, Office 302,  
Dembel, Addis Ababa,  
Ethiopia

**Figure 12 - Backpressure, Capacity Model, and Load Shedding**

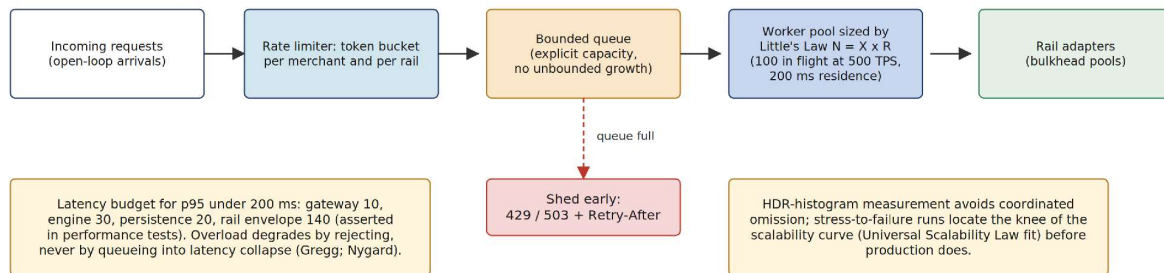


Figure 12. Backpressure, capacity model, and load shedding: Little's Law sizing, per-component latency budget, and early rejection under overload to protect the p95 target (Gregg; Nygard).

### 3.6.1 Quantitative Basis for the Performance Targets

| Quantity                     | Relationship                                                                                                           | At 500 TPS                                      | At 2,000 TPS                                 |
|------------------------------|------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------|----------------------------------------------|
| Requests in flight           | Little's Law: $N = X \times R$ , with $R = 0.2$ s                                                                      | $N = 100$                                       | $N = 400$                                    |
| Worker threads (engine tier) | $c = (\lambda \times S) / \rho$ , service time $S = 50$ ms, utilization cap $\rho = 0.7$                               | $c \approx 36$ (e.g. 6 pods $\times$ 6 threads) | $c \approx 143$ (24 pods $\times$ 6 threads) |
| Queueing safety margin       | M/M/1 approximation: $R \approx S / (1 - \rho)$ ; $R = 3.3 \times S$ at $\rho = 0.7$ but $10 \times S$ at $\rho = 0.9$ | latency stable under cap                        | latency stable under cap                     |
| p95 latency budget           | $\Sigma$ stage budgets = 10 + 30 + 20 + 140 = 200 ms; each stage asserted in tests                                     | met                                             | met                                          |

#### Email

contact@sydek.dev

#### Phone

+251 912983759  
+251 911971885  
+251 712785587

#### Location

Kebede Haile Building,  
3rd Floor, Office 302,  
Dembel, Addis Ababa,  
Ethiopia

| Quantity            | Relationship                                                                                           | At 500 TPS                               | At 2,000 TPS                          |
|---------------------|--------------------------------------------------------------------------------------------------------|------------------------------------------|---------------------------------------|
| Scalability ceiling | USL: $C(N) = N / (1 + \sigma(N - 1) + \kappa N(N - 1))$ ; knee at $N^* = \sqrt{((1 - \sigma)/\kappa)}$ | $\sigma, \kappa$ fitted from stress runs | replica count held below fitted $N^*$ |

Two of these numbers carry most of the design weight. First, utilization is capped at  $\rho \leq 0.7$  because queueing delay grows hyperbolically as  $\rho \rightarrow 1$ : the same worker that responds in  $3.3 \times S$  at 70% utilization responds in  $10 \times S$  at 90%, which is why autoscaling triggers on utilization and queue depth rather than on failure. Second, the Universal Scalability Law coefficients  $\sigma$  (contention) and  $\kappa$  (coherence) are fitted from stress-to-failure data in Phase 2, so the knee of the scalability curve is known analytically before production traffic finds it empirically (Gregg).

### 3.7 Architecture Governance

The SADD covering all seven areas mandated in TOR 3.2.1 (microservice decomposition, API design, data schema, infrastructure topology, security architecture, network/DMZ design, and integration architecture) is delivered in Month 1, presented to HISAB technical and business teams, and baselined before development. Significant decisions are recorded as Architecture Decision Records appended to the SADD, giving HISAB a complete design rationale at handover.

### 3.8 Architecture Figures (SADD Preview)

Figures 1 to 4 and 6 to 15 appear inline at their relevant sections (3.2 to 3.6, 6.1, 7.1, and 8.6); Figure 5 appears below. The register lists all figures with their editable Lucidchart sources (view access available to the evaluation committee on request), which serve as the working figures of the SADD.

| Figure | Title                | What it shows                                                                                                 | Lucid Document                                     |
|--------|----------------------|---------------------------------------------------------------------------------------------------------------|----------------------------------------------------|
| Fig. 1 | Logical Architecture | Bounded contexts across Edge/DMZ, Application, Data, and Rail Integration zones; clients to rails end-to-end, | HISAB Payment Gateway, System Architecture, page 1 |

#### Email

contact@sydek.dev

#### Phone

+251 912983759  
+251 911971885  
+251 712785587

#### Location

Kebede Haile Building,  
3rd Floor, Office 302,  
Dembel, Addis Ababa,  
Ethiopia

| Figure | Title                               | What it shows                                                                                                                                                               | Lucid Document                                       |
|--------|-------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------|
|        |                                     | with the isolated tokenization/CHD zone                                                                                                                                     |                                                      |
| Fig. 2 | Deployment & Network Topology       | Dual availability-zone, in-country deployment: Kubernetes pools, PostgreSQL synchronous replication, Kafka cross-zone replication, HSM/Vault, CI/CD, backup (RPO<1h/RTO<4h) | Same document, page 2                                |
| Fig. 3 | Transaction Lifecycle State Machine | INITIATED → ROUTED → SUBMITTED → AUTHORIZED/CAPTURED → SETTLED with FAILED, REVERSED, and PENDING_CONFIRMATION resolution paths (no guessed outcomes)                       | Same document, page 3                                |
| Fig. 4 | Rail Adapter Pattern                | Anti-corruption layer internals per rail: translation, idempotent submission journal, stability patterns, status reconciler feeding the reconciliation engine and ledger    | Same document, page 4                                |
| Fig. 5 | Payment Flow Sequence               | End-to-end Telebirr wallet payment: idempotency check, outbox, rail callback verification, double-entry                                                                     | HISAB Payment Gateway, Payment Flow Sequence Diagram |

#### Email

contact@sydek.dev

#### Phone

+251 912983759  
+251 911971885  
+251 712785587

#### Location

Kebede Haile Building,  
3rd Floor, Office 302,  
Dembel, Addis Ababa,  
Ethiopia

| Figure  | Title                        | What it shows                                                                                | Lucid Document                             |
|---------|------------------------------|----------------------------------------------------------------------------------------------|--------------------------------------------|
|         |                              | posting, signed merchant webhook                                                             |                                            |
| Fig. 6  | Kubernetes Cluster Structure | Dual-zone worker pools, HPA, pod anti-affinity, namespace isolation, PodDisruptionBudgets    | Reliability and Clustering Figures, page 1 |
| Fig. 7  | HA and Failover Scenarios    | Failure-to-outcome matrix: pod, node, zone, rail, and site failures with automated responses | Same document, page 2                      |
| Fig. 8  | PostgreSQL HA Cluster        | Sync standby (zero loss), async read replica, automated promotion, WAL archiving and PITR    | Same document, page 3                      |
| Fig. 9  | Kafka Cluster                | Partition leadership across brokers, RF=3 / min ISR=2, consumer groups, dead-letter topics   | Same document, page 4                      |
| Fig. 10 | Transactional Outbox         | Exactly-once effects over at-least-once delivery; crash points analyzed                      | Same document, page 5                      |
| Fig. 11 | Derived Data / CQRS          | System of record feeding rebuildable views; independent invariant checker                    | Same document, page 6                      |

#### Email

contact@sydek.dev

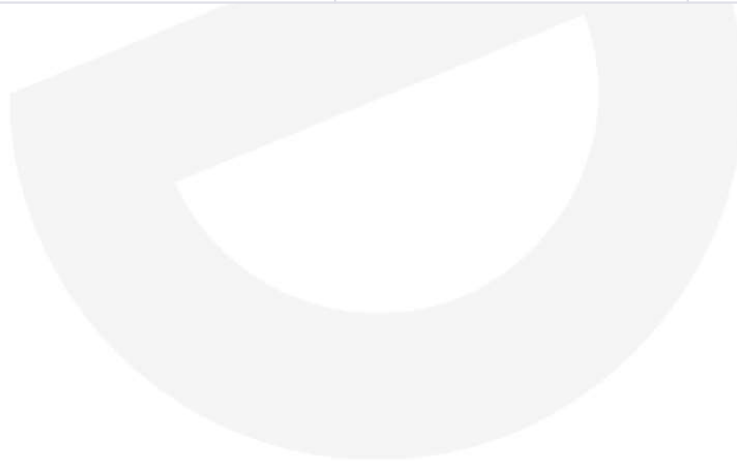
#### Phone

+251 912983759  
+251 911971885  
+251 712785587

#### Location

Kebede Haile Building,  
3rd Floor, Office 302,  
Dembel, Addis Ababa,  
Ethiopia

| Figure  | Title                          | What it shows                                                                  | Lucid Document         |
|---------|--------------------------------|--------------------------------------------------------------------------------|------------------------|
| Fig. 12 | Backpressure and Load Shedding | Little's Law sizing, latency budget allocation, early rejection under overload | Same document, page 7  |
| Fig. 13 | Circuit Breaker State Machine  | Closed / open / half-open transitions per rail adapter with bulkhead isolation | Same document, page 8  |
| Fig. 14 | Defense in Depth               | Nine control layers mapped to Anderson's security engineering framework        | Same document, page 9  |
| Fig. 15 | Disaster Recovery Timeline     | RPO under 1 hour and RTO under 4 hours with pre-go-live rehearsal evidence     | Same document, page 10 |



#### Email

[contact@sydek.dev](mailto:contact@sydek.dev)

#### Phone

+251 912983759  
+251 911971885  
+251 712785587

#### Location

Kebede Haile Building,  
3rd Floor, Office 302,  
Dembel, Addis Ababa,  
Ethiopia

 [sydek.dev](https://sydek.dev)

**Figure 5 - End-to-End Payment Flow (Telebirr wallet rail, representative)**

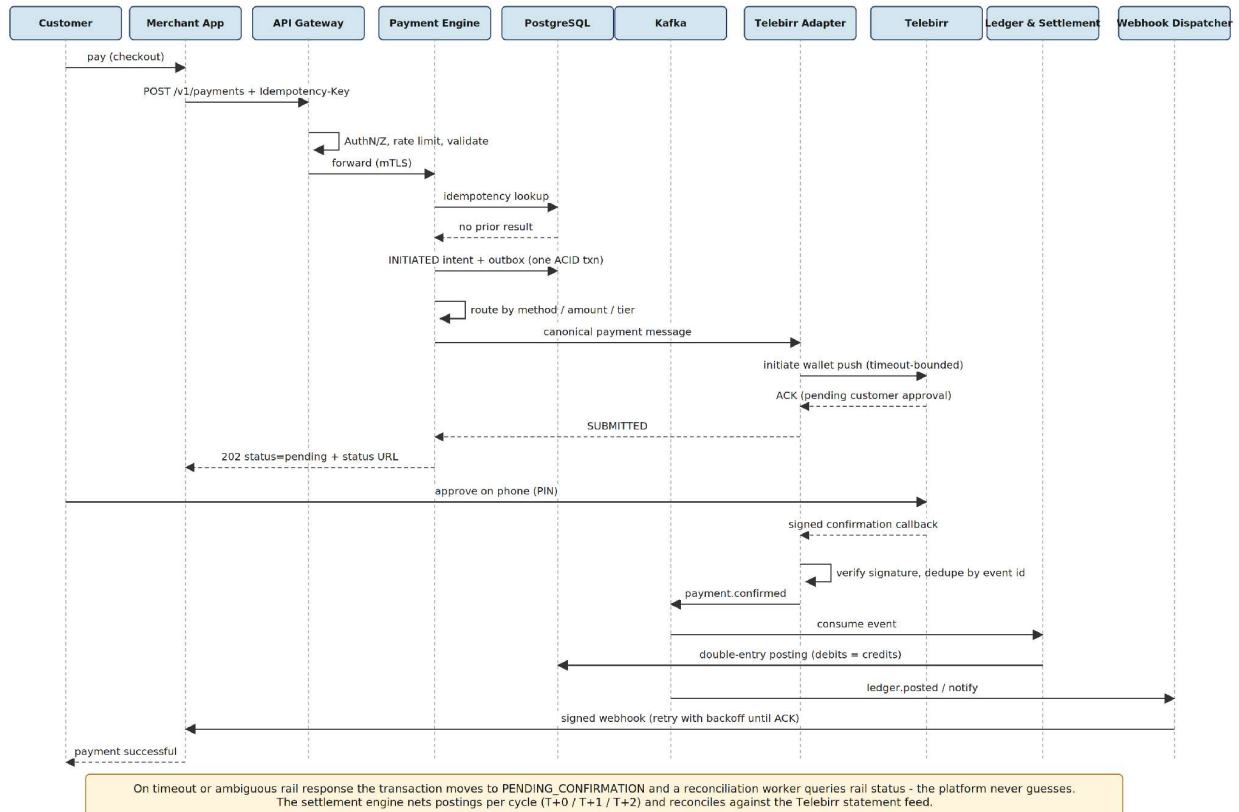


Figure 5. End-to-end payment flow on the Telebirr wallet rail (representative): idempotency, outbox, callback verification, ledger posting, signed merchant webhook.

### Email

contact@sydek.dev

### Phone

+251 912983759  
+251 911971885  
+251 712785587

### Location

Kebede Haile Building,  
3rd Floor, Office 302,  
Dembel, Addis Ababa,  
Ethiopia

## 4. Technology Stack

The stack satisfies every characteristic mandated in TOR 6.1 and is chosen for one property above all: boring, proven reliability in regulated payment systems, with deep local and global talent pools so HISAB can operate the platform after handover.

### 4.1 Proposed Stack

| Layer                  | Technology                    | Rationale                                                                                                                                                              |
|------------------------|-------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Backend services       | Java 21 LTS / Spring Boot 3.x | Compiled, enterprise-grade per TOR 6.1; mature transaction management, observability, and security ecosystem; dominant in banking; HISAB-specified SDK sample language |
| Frontend portals       | React 18 + TypeScript         | Modern framework per TOR 6.1; shared component library across admin, merchant, and developer portals                                                                   |
| Transactional database | PostgreSQL 16                 | ACID, mature replication, declarative partitioning, row-level security; strong audit story                                                                             |
| Cache                  | Redis 7                       | Routing/config cache, idempotency lookups, rate-limit counters                                                                                                         |
| Event streaming        | Apache Kafka                  | Durable, replayable event backbone; schema registry for contract governance                                                                                            |

#### Email

[contact@sydek.dev](mailto:contact@sydek.dev)

#### Phone

+251 912983759  
+251 911971885  
+251 712785587

#### Location

Kebede Haile Building,  
3rd Floor, Office 302,  
Dembel, Addis Ababa,  
Ethiopia

| Layer                      | Technology                                         | Rationale                                                                                     |
|----------------------------|----------------------------------------------------|-----------------------------------------------------------------------------------------------|
| Containers & orchestration | Docker + Kubernetes                                | TOR 6.1 mandate; autoscaling, multi-zone scheduling, rolling deploys                          |
| Infrastructure as code     | Terraform + Helm                                   | TOR 3.2.12 mandate; reproducible environments, reviewable infrastructure changes              |
| CI/CD                      | GitLab CI (or HISAB-preferred equivalent)          | Pipeline-enforced quality and security gates; signed, traceable artifacts                     |
| Observability              | Prometheus + Grafana + ELK + OpenTelemetry tracing | TOR 3.2.12; per-rail SLIs, latency histograms, audit-grade centralized logs                   |
| Secrets & keys             | HashiCorp Vault + HSM (PKCS#11)                    | Key hierarchy per NIST SP 800-57; tokenization vault isolation                                |
| Identity                   | Keycloak (OIDC/OAuth 2.1)                          | MFA, RBAC, federation for admin/merchant portals and APIs                                     |
| API specification          | OpenAPI 3.0 + GraphQL (reporting)                  | TOR 3.2.5; generated interactive docs, client SDK generation for Android/iOS/Web/Java/Node.js |

## 4.2 Stack Risk Posture

Every component is open-source or license-unencumbered for HISAB's exclusive ownership model (TOR 6.4): there are no per-transaction license fees, no vendor lock-in to our firm, and no component HISAB cannot hire for in Addis Ababa or operate via a managed-service partner. Versions are pinned LTS releases; the software bill of materials (SBOM) is delivered with the source repository and continuously scanned for CVEs during the engagement (Section 7.6).

### Email

[contact@sydek.dev](mailto:contact@sydek.dev)

### Phone

+251 912983759  
+251 911971885  
+251 712785587

### Location

Kebede Haile Building,  
3rd Floor, Office 302,  
Dembel, Addis Ababa,  
Ethiopia

### 4.3 Data Residency and Hosting

Primary and standby environments are deployed in-country to satisfy NBE data-residency expectations and Proclamation 1321/2024 cross-border transfer restrictions, on infrastructure jointly selected with HISAB in Phase 1 (evaluated options: Ethio Telecom cloud/colocation, certified local data centers, or HISAB-procured infrastructure under our IaC). The architecture is provider-portable by construction (Kubernetes + Terraform), so a hosting decision is not a re-architecture decision.

#### **Email**

[contact@sydek.dev](mailto:contact@sydek.dev)

#### **Phone**

+251 912983759  
+251 911971885  
+251 712785587

#### **Location**

Kebede Haile Building,  
3rd Floor, Office 302,  
Dembel, Addis Ababa,  
Ethiopia

## 5. Regulatory Strategy

### 5.1 Strategy Overview

This section explains how we take HISAB from its current position to a licensed payment platform running in production. It answers the three things the TOR asks for: the approach to NBE licensing, the AML/CFT framework, and ongoing compliance management. The regulatory track (Track A) runs in parallel with platform development (Track B) so that controls are built into the system rather than bolted on later.

Two principles guide the work. First, the license is held by HISAB as the applicant; we prepare, compile, and manage the application end to end, and HISAB performs the acts only an applicant can perform, such as depositing capital and passing board resolutions. Second, every control the NBE expects on paper is also implemented in the platform, so that what HISAB commits to in its policy manuals is enforced in software and evidenced in its reports.

### 5.2 NBE Licensing Approach

#### Confirm the licensing pathway

The first deliverable is a regulatory landscape assessment that confirms the exact license category for a payment gateway aggregator under the NBE oversight framework set by Proclamation No. 718/2011. The assessment maps the applicable directives, the responsible authorities, the fee schedule, and the dependencies, and fixes the capital and documentary requirements that apply to HISAB before any drafting begins. The requirements summarised below follow Directive ONPS/02/2020 and are confirmed against the operator-specific directive in that assessment.

#### Corporate and capital readiness

We confirm HISAB meets the structural conditions for licensing before submission, so the application is not held up on eligibility:

- **Minimum paid-up capital in cash:** held in a blocked bank account in the applicant's name, as required by the NBE directive (subject to confirmation against the operator-specific directive).

#### Email

[contact@sydek.dev](mailto:contact@sydek.dev)

#### Phone

+251 912983759  
+251 911971885  
+251 712785587

#### Location

Kebede Haile Building,  
3rd Floor, Office 302,  
Dembel, Addis Ababa,  
Ethiopia

- **Ownership:** no shareholder other than the Government may hold more than 20 percent, and the company must have at least 10 shareholders.
- **Constitution:** memorandum and articles of association approved by the NBE before registration, with board resolutions authorising the application.

## Application dossier and policy manuals

We prepare the complete NBE application dossier: the business plan covering at least five years, financial projections, governance and organisational structure, the technical and system conditions, and the operational policies and procedures. The dossier includes the six policy manuals the NBE mandates, each written to be enforceable rather than decorative:

- Anti-Money Laundering and Counter-Financing of Terrorism (AML/CFT) policy.
- Consumer protection policy.
- Cybersecurity and data security policy.
- Business continuity and disaster recovery policy.
- Risk management framework covering operational, technology, cyber, third-party, liquidity, reputational, and legal risk.
- Operational and internal control policies.

## Fit-and-proper for key personnel

The NBE assesses HISAB's directors and executives against fixed criteria and requires prior written approval for their appointment. We compile the fit-and-proper dossier, screen each person against the criteria, and remediate gaps before submission.

| Role     | NBE minimum requirement                                                                                                                                             |
|----------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Director | First degree or equivalent; adequate experience and prior understanding of payment instruments; at least 30 years old; signed biography and CV; prior NBE approval. |

### Email

[contact@sydek.dev](mailto:contact@sydek.dev)

### Phone

+251 912983759  
+251 911971885  
+251 712785587

### Location

Kebede Haile Building,  
3rd Floor, Office 302,  
Dembel, Addis Ababa,  
Ethiopia

| Role                     | NBE minimum requirement                                                                                                                                 |
|--------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------|
| Chief Executive Officer  | First degree; minimum 10 years in finance and payments, of which 5 in a senior executive role; credentials from previous employers; prior NBE approval. |
| Senior Executive Officer | First degree; minimum 8 years experience, of which 3 at managerial level; signed biography and CV; prior NBE approval.                                  |

## Two-stage approval and pilot

Where the NBE opts for a staged process, it grants primary approval for piloting before final approval for operation. We plan for this from the start:

- **Pilot window:** the pilot runs for a maximum of three months, extendable by one month on written request.
- **Pilot start:** a detailed pilot plan is submitted and the pilot commences within 30 calendar days of notification.
- **Pilot reporting:** monthly performance reports during the pilot and a final report within 30 calendar days of pilot end.
- **Decision and launch:** the NBE responds within 60 calendar days of the last date all required conditions are met, and HISAB must commence operation within six months of license issue.

***License issuance timelines are set by the NBE and are outside the vendor's control. We are accountable for a complete, query-resistant application and for timely follow-up; actual issuance dates may vary with NBE processing periods.***

## Statutory fees

| NBE statutory fee               | Amount    |
|---------------------------------|-----------|
| Application / investigation fee | ETB 5,000 |
| Licensing fee                   | ETB 5,000 |

### Email

contact@sydek.dev

### Phone

+251 912983759  
+251 911971885  
+251 712785587

### Location

Kebede Haile Building,  
3rd Floor, Office 302,  
Dembel, Addis Ababa,  
Ethiopia

| NBE statutory fee                    | Amount    |
|--------------------------------------|-----------|
| New product or service authorization | ETB 3,000 |
| Annual renewal fee                   | ETB 5,000 |

## Licensing roadmap

| Step                    | What we deliver                                                                                                   | Timing      |
|-------------------------|-------------------------------------------------------------------------------------------------------------------|-------------|
| Landscape & roadmap     | Confirm license category, map ONPS directives, fee schedule, authorities, and dependencies.                       | Month 1     |
| Application dossier     | Corporate and governance documents, five-year business plan, financial projections, technical feasibility.        | Month 2     |
| Six policy manuals      | AML/CFT, consumer protection, cybersecurity and data security, BCP/DR, risk management, internal control.         | Month 2     |
| AML/CFT framework       | CDD and EDD procedures, monitoring rules and thresholds, SAR workflow, sanctions screening.                       | Month 2     |
| Data protection package | Privacy, data retention, and data subject rights procedures; residency and localisation advice.                   | Month 2     |
| Reporting templates     | NBE periodic reporting templates, automated submissions, and a compliance calendar.                               | Month 3     |
| Submission & review     | Submit the dossier; manage queries, meetings, demonstrations, and on-site inspections; run the pilot if required. | Months 2-6  |
| License obtained        | Primary approval for piloting, then final approval; commence operation within six months.                         | Months 4-6* |

### Email

contact@sydek.dev

### Phone

+251 912983759  
+251 911971885  
+251 712785587

### Location

Kebede Haile Building,  
3rd Floor, Office 302,  
Dembel, Addis Ababa,  
Ethiopia

### 5.3 AML/CFT Framework

We build a full AML/CFT framework aligned with Proclamation No. 780/2011 on the Prevention and Suppression of Money Laundering and the Financing of Terrorism, the NBE directives, and the FATF recommendations. The framework is documented in policy and enforced in the platform.

#### Customer and business due diligence

Customer due diligence (CDD) follows the tiered Know Your Customer model in the NBE directive, with enhanced due diligence (EDD) for higher-risk customers and politically exposed persons. Merchant and institution onboarding (KYB) validates business licenses, tax identification, and ownership before activation. The account tiers and limits the system enforces are:

| Account level | Max balance | Daily limit | Monthly limit |
|---------------|-------------|-------------|---------------|
| Level 1       | ETB 5,000   | ETB 1,000   | ETB 10,000    |
| Level 2       | ETB 20,000  | ETB 5,000   | ETB 40,000    |
| Level 3       | ETB 30,000  | ETB 8,000   | ETB 60,000    |
| Walk-in user  | n/a         | ETB 500     | n/a           |

Two-factor authentication is enforced for transaction amounts above ETB 1,000, in line with the NBE directive. Identity documents captured at each level match the directive's requirements.

#### Transaction monitoring and sanctions screening

- **Monitoring:** configurable monitoring rules and thresholds run inside the platform, flagging velocity, structuring, and behavioural anomalies in real time.
- **Screening:** screening against applicable sanctions lists at onboarding and on an ongoing basis, with politically exposed person checks.
- **Configurability:** rule changes apply without code deployment, so thresholds track regulatory and risk changes.

#### Email

contact@sydek.dev

#### Phone

+251 912983759  
+251 911971885  
+251 712785587

#### Location

Kebede Haile Building,  
3rd Floor, Office 302,  
Dembel, Addis Ababa,  
Ethiopia

## Suspicious activity reporting

- **SAR workflow:** a suspicious activity reporting (SAR) workflow routes flagged cases to the compliance officer for review and onward reporting to the Financial Intelligence service and the NBE.
- **Evidence:** every alert, decision, and report is recorded with actor and timestamp for audit.

## Governance, training, and recordkeeping

- **Ownership:** a designated AML/CFT compliance officer owns the framework, supported by a CAMS-certified specialist on the delivery team.
- **Training:** staff training on AML/CFT obligations, refreshed on a fixed schedule.
- **Recordkeeping:** records retained for the period required by the governing proclamation, with the directive's ten-year retention applied to closed-account data.
- **Assurance:** independent testing of the framework before go-live and on a recurring basis thereafter.

## 5.4 Compliance Management

Compliance does not end at licensing. We hand HISAB a framework that keeps it compliant in operation, with reporting automated where the platform can do so.

## Regulatory reporting

We implement the NBE reporting templates and automate statutory submissions inside the platform, then hand over a compliance calendar so no deadline is missed:

| Obligation                                                                                  | Frequency and deadline                           | Source        |
|---------------------------------------------------------------------------------------------|--------------------------------------------------|---------------|
| Operational and statistical report (accounts, volumes, agents, complaints, fraud, breaches) | Quarterly, within 7 calendar days of quarter end | NBE directive |
| Fraud incident report                                                                       | Within 5 working days of the incident            | NBE directive |

### Email

contact@sydek.dev

### Phone

+251 912983759  
+251 911971885  
+251 712785587

### Location

Kebede Haile Building,  
3rd Floor, Office 302,  
Dembel, Addis Ababa,  
Ethiopia

| Obligation                          | Frequency and deadline                                  | Source        |
|-------------------------------------|---------------------------------------------------------|---------------|
| Audited financial statements (IFRS) | Annually, within 60 calendar days of fiscal year end    | NBE directive |
| Float reconciliation summary        | Daily, by 10:00 AM the following day                    | NBE directive |
| System or operation change notice   | 30 days before the change; users notified 7 days before | NBE directive |
| License renewal                     | Annually, within 90 calendar days of fiscal year end    | NBE directive |

## Customer protection and complaints

- **Channel:** an accessible complaint channel open beyond normal working hours, with each complaint assigned a reference and registered.
- **Resolution:** complaints addressed within a maximum of three working days, with a right of appeal to a higher-level officer.
- **Transparency:** terms and conditions, fees, and agent lists published, with NBE approval obtained before changes to terms.

## Data protection and privacy

The platform and its operations comply with the Personal Data Protection Proclamation No. 1321/2024 and NBE data governance directives. We deliver a privacy policy, a data retention policy, and data subject rights procedures, and we deploy on infrastructure that meets NBE data residency requirements.

## Security certification and assurance

Security controls that underpin the license are delivered and evidenced:

- **INSA:** complete the first-round INSA certification and align with INSA requirements.
- **PCI-DSS:** a PCI-DSS compliance roadmap with applicable controls implemented within scope.

### Email

[contact@sydek.dev](mailto:contact@sydek.dev)

### Phone

+251 912983759  
+251 911971885  
+251 712785587

### Location

Kebede Haile Building,  
3rd Floor, Office 302,  
Dembel, Addis Ababa,  
Ethiopia

- **Standards:** ISO 27001-aligned information security practices and OWASP Top 10 mitigation in the application layer.
- **Testing:** encryption at rest and in transit, with annual penetration testing and vulnerability assessment.

## Governance and liaison

We serve as the primary regulatory liaison with the NBE on HISAB's behalf: coordinating meetings and demonstrations, preparing responses to queries within required timelines, and supporting on-site inspections. A bi-weekly regulatory coordination call and the joint steering committee keep licensing and build aligned through to go-live.

## 5.5 Roles and Accountabilities

The license is HISAB's; the work to obtain and keep it is ours. The split below removes ambiguity over who does what.

| Activity                                          | Vendor                  | HISAB                            |
|---------------------------------------------------|-------------------------|----------------------------------|
| Landscape assessment, dossier, and policy manuals | Prepare and deliver     | Review and approve               |
| Capital deposit and shareholder structure         | Advise and verify       | Provide and execute              |
| Board resolutions and signatory acts              | Draft supporting papers | Pass and sign                    |
| Fit-and-proper submissions                        | Compile and screen      | Supply personnel and credentials |
| NBE submission, queries, and inspections          | Lead and manage         | Authorise and attend             |
| In-platform AML/CFT and reporting controls        | Build and hand over     | Operate post-handover            |

## 5.6 Regulatory Risks and Mitigations

### Email

contact@sydek.dev

### Phone

+251 912983759  
+251 911971885  
+251 712785587

### Location

Kebede Haile Building,  
3rd Floor, Office 302,  
Dembel, Addis Ababa,  
Ethiopia

| Regulatory risk                                                            | Mitigation                                                                                                                                             |
|----------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------|
| License category uncertainty (operator or aggregator vs instrument issuer) | Confirm the classification in the Month 1 landscape assessment against the applicable ONPS directives before drafting the dossier.                     |
| NBE processing time outside our control                                    | Submit a complete, query-resistant dossier; assign a dedicated liaison; answer queries within required timelines; run the technical build in parallel. |
| Capital and ownership readiness                                            | Confirm paid-up capital and shareholder structure early; deposit capital in the blocked account before submission.                                     |
| Fit-and-proper gaps in key personnel                                       | Screen directors and executives against the directive criteria at the outset and remediate before submission.                                          |
| Pilot performance shortfall                                                | Agree pilot success metrics with the NBE; run the 2 to 3 institution pilot with monitoring; submit monthly and final reports on time.                  |
| Data residency constraints                                                 | Deploy on infrastructure that meets NBE residency requirements; confirm localisation in the data protection package.                                   |
| AML/CFT findings                                                           | Build monitoring, screening, and SAR workflows into the platform; align to Proclamation 780/2011 and FATF; test independently before go-live.          |
| Third-party rail approvals (EthSwitch, Telebirr, CBE Birr)                 | Begin integration approvals early and track each rail certification as a named dependency.                                                             |

## 5.7 Key Assumptions

- The NBE license is issued to HISAB as the applicant; we prepare, compile, and manage the application, and HISAB executes board approvals, the capital deposit, and signatory acts.
- HISAB provides corporate documents, audited financials, and the access required for regulatory submissions within agreed timelines.

### Email

contact@sydek.dev

### Phone

+251 912983759  
+251 911971885  
+251 712785587

### Location

Kebede Haile Building,  
3rd Floor, Office 302,  
Dembel, Addis Ababa,  
Ethiopia

- Statutory figures cited are confirmed against the directive applicable to HISAB's license category during the landscape assessment.
- NBE processing periods, pilot duration, and inspection scheduling are determined by the NBE and may affect issuance dates.
- AML/CFT obligations follow Proclamation No. 780/2011, the NBE directives, and the FATF recommendations.

**Email**

[contact@sydek.dev](mailto:contact@sydek.dev)

**Phone**

+251 912983759  
+251 911971885  
+251 712785587

**Location**

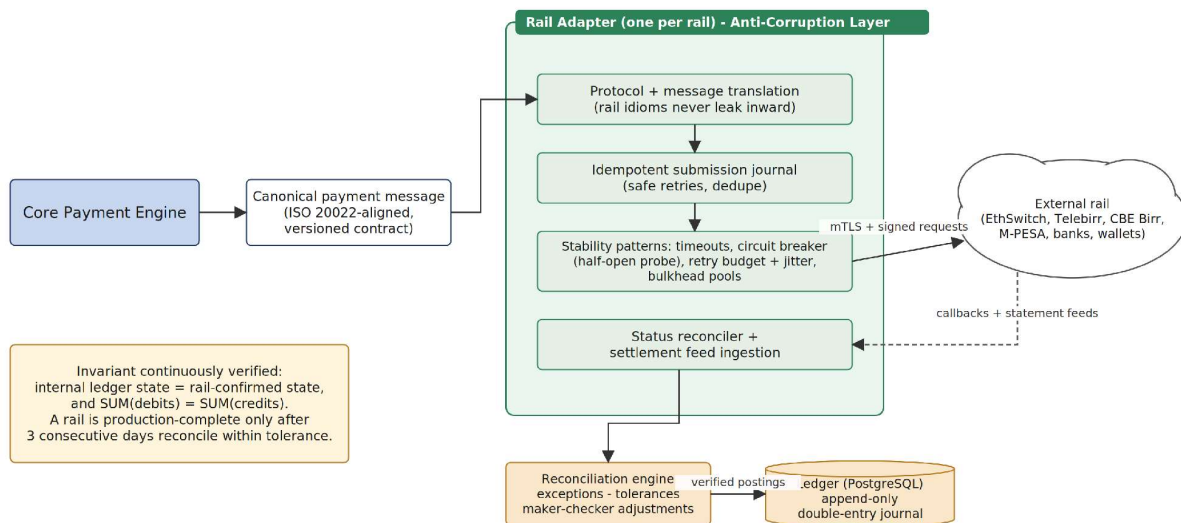
Kebede Haile Building,  
3rd Floor, Office 302,  
Dembel, Addis Ababa,  
Ethiopia

## 6. Integration Plan, Ethiopian Payment Rails

### 6.1 Integration Architecture

The adapter pattern is diagrammed in Figure 4.

**Figure 4 - Rail Adapter Pattern (Anti-Corruption Layer)**



*Figure 4. Rail Adapter Pattern: anti-corruption layer internals feeding the reconciliation engine and double-entry ledger.*

Every rail in TOR 3.2.3 is integrated through a dedicated adapter implementing a single canonical internal contract (an ISO 20022-aligned payment message model) behind an anti-corruption layer (Evans; Hohpe & Woolf). The adapter owns: protocol translation, credential and certificate management, idempotent submission journaling, timeout/circuit-breaker/retry policy (Nygard), rail-specific status reconciliation, and per-rail observability (success rate, latency histograms, error taxonomy). New rails are added by writing one adapter against the certified contract test suite, the platform core does not change. This is the mechanism that makes the TOR's mandatory/high/medium rail tiers a sequencing decision rather than an architectural one.

#### Email

contact@sydek.dev

#### Phone

+251 912983759  
+251 911971885  
+251 712785587

#### Location

Kebede Haile Building,  
3rd Floor, Office 302,  
Dembel, Addis Ababa,  
Ethiopia

**Figure 13 - Circuit Breaker State Machine (per rail adapter)**

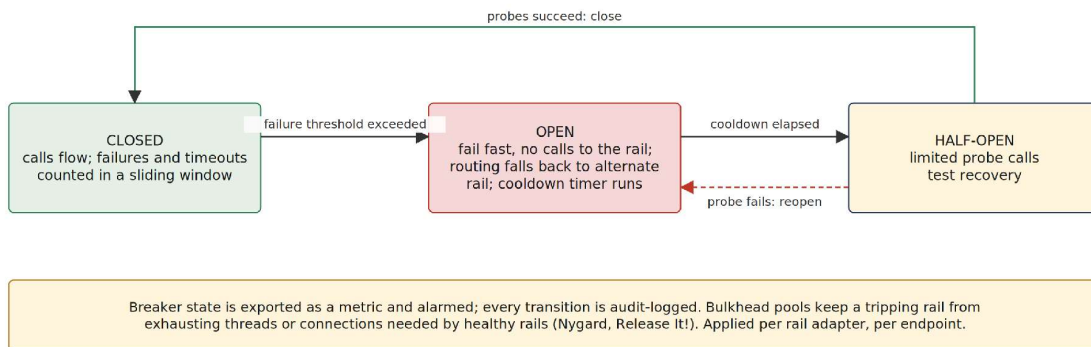


Figure 13. Circuit breaker state machine applied per rail adapter, with bulkhead isolation so one degraded rail never exhausts shared resources (Nygard, Release It!).

Retry policy is sized, not guessed. Against a healthy rail where a single attempt succeeds with probability  $p = 0.99$ , a budget of three attempts lifts end-to-end success to  $1 - (1 - p)^3 = 99.9999\%$ , so almost all transient faults are absorbed invisibly. Against an unhealthy rail the same mechanism inverts: if a fraction  $r$  of calls are retried, offered load is amplified by a factor of  $1/(1 - r)$ , approaching a self-inflicted denial of service as  $r$  grows. That asymmetry is exactly why retries are bounded by budget, spread by exponential backoff with jitter so a recovering rail is not re-saturated at one instant, and cut off entirely by the circuit breaker in Figure 13 (Nygard).

## 6.2 Rail-by-Rail Approach and Sequencing

| Rail                        | Priority (TOR) | Integration Pattern                                                            | Sequencing & Notes                                                                          |
|-----------------------------|----------------|--------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------|
| EthSwitch (national switch) | Mandatory      | Full interoperability-layer integration; certification per EthSwitch test plan | Engagement opens Month 1 (longest certification lead time); sandbox conformance before live |
| Telebirr (Ethio Telecom)    | Mandatory      | Wallet API: initiation (push/USSD prompt),                                     | First live rail target (largest user base); webhook +                                       |

### Email

contact@sydek.dev

### Phone

+251 912983759  
+251 911971885  
+251 712785587

### Location

Kebede Haile Building,  
3rd Floor, Office 302,  
Dembel, Addis Ababa,  
Ethiopia

| Rail                        | Priority (TOR) | Integration Pattern                                                           | Sequencing & Notes                                                        |
|-----------------------------|----------------|-------------------------------------------------------------------------------|---------------------------------------------------------------------------|
|                             |                | confirmation callback, settlement feed                                        | polling fallback for status truth                                         |
| CBE Birr                    | Mandatory      | Mobile money initiation, confirmation, settlement                             | Parallel with Telebirr; shared wallet-adapter framework                   |
| M-PESA (Safaricom Ethiopia) | Mandatory      | Standard M-PESA API suite (STK push, callbacks, reversal)                     | Well-documented APIs; team has regional M-PESA pattern experience         |
| Ethiopian banks (bilateral) | Mandatory      | Direct bank APIs where EthSwitch coverage is insufficient                     | Prioritized by HISAB's anchor merchants; bank-by-bank certification gates |
| Dashen Super App            | Mandatory      | Wallet-rail integration via published APIs                                    | Phase 2 wave 2                                                            |
| E-Birr / Awash Wallet       | High           | Wallet adapters on the shared framework                                       | Phase 2 wave 2-3                                                          |
| Apollo (Bank of Abyssinia)  | High           | Mobile-banking integration                                                    | Phase 2 wave 3                                                            |
| QR payments                 | High           | Static & dynamic QR generation/scanning; alignment with national QR standards | Delivered with merchant tooling in wave 2                                 |
| USSD channel                | Medium         | USSD gateway integration for feature-phone initiation                         | Phase 2 wave 3; aggregator-mediated                                       |

#### Email

[contact@sydek.dev](mailto:contact@sydek.dev)

#### Phone

+251 912983759  
+251 911971885  
+251 712785587

#### Location

Kebede Haile Building,  
3rd Floor, Office 302,  
Dembel, Addis Ababa,  
Ethiopia

| Rail              | Priority (TOR) | Integration Pattern                                                                    | Sequencing & Notes                                                               |
|-------------------|----------------|----------------------------------------------------------------------------------------|----------------------------------------------------------------------------------|
| Visa / Mastercard | Medium         | International card processing via licensed acquiring partner, subject to NBE/CBE scope | Feasibility memo in Phase 1; tokenized, PCI-scoped path reserved in architecture |

### 6.3 Integration Method per Rail

Each rail follows the same six-step pipeline with explicit exit criteria: (1) Technical discovery: API documentation review, sandbox access, credential/certificate exchange, commercial/settlement account setup with HISAB; (2) Adapter development against a rail simulator we build from the rail's documented behavior, including its failure modes (timeouts, ambiguous responses, duplicate callbacks); (3) Contract testing: consumer-driven contract tests pin the adapter to observed sandbox behavior so partner-side changes are detected in CI, not in production; (4) Certification: execution of the partner's formal test plan and sign-off; (5) Controlled go-live, canary traffic with tightened alerting and instant routing fallback to alternate rails where available; (6) Reconciliation activation: ingestion of the rail's settlement/statement feed into the reconciliation engine, with the rail declared production-complete only when three consecutive days reconcile within tolerance.

### 6.4 Dependencies and De-risking

Rail integrations are the program's highest-variance external dependency (Section 10, R2-R4). We de-risk by: opening all mandatory-rail commercial and sandbox-access conversations in Month 1 under HISAB's introductions (TOR Section 12); building against simulators so partner sandbox downtime never blocks development; sequencing certification slots early for EthSwitch; and designing routing so go-live can proceed on a quorum of mandatory rails with remaining rails activated incrementally, protecting Deliverable 23 (production go-live, Month 8) from any single partner's calendar.

#### Email

[contact@sydek.dev](mailto:contact@sydek.dev)

#### Phone

+251 912983759  
+251 911971885  
+251 712785587

#### Location

Kebede Haile Building,  
3rd Floor, Office 302,  
Dembel, Addis Ababa,  
Ethiopia

## 7. Security Plan

### 7.1 Security Engineering Framework

Following Anderson's Security Engineering, we treat security as the alignment of four things: policy (what must be protected, from whom, codified in the Cybersecurity and Data Security Policy of Section 5.2), mechanism (the controls below), assurance (evidence the mechanisms work, tests, audits, penetration tests), and incentives (operational processes that keep people doing the secure thing). The plan below is organized accordingly, and every control maps to at least one of: NBE directive obligations, INSA certification criteria, PCI-DSS v4.0 requirements, ISO/IEC 27001:2022 Annex A controls, or OWASP ASVS verification items, the traceability matrix is a deliverable with the SADD.

**Figure 14 - Defense in Depth (Anderson: policy, mechanism, assurance, incentives)**

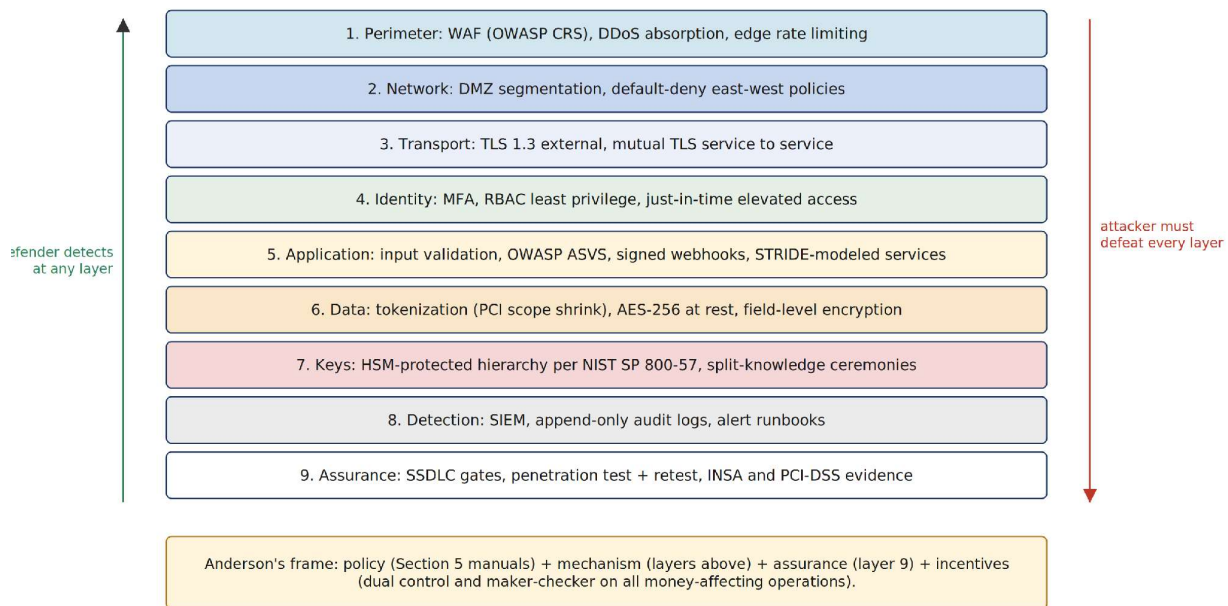


Figure 14. Defense in depth: nine control layers mapped to Anderson's policy, mechanism, assurance, and incentives framework.

#### Email

contact@sydek.dev

#### Phone

+251 912983759  
+251 911971885  
+251 712785587

#### Location

Kebede Haile Building,  
3rd Floor, Office 302,  
Dembel, Addis Ababa,  
Ethiopia

 sydek.dev

## 7.2 Threat Modeling

Each bounded context undergoes STRIDE threat modeling (spoofing, tampering, repudiation, information disclosure, denial of service, elevation of privilege) during design, before code. Payment-specific threat scenarios receive dedicated analysis: replay and double-spend (countered by idempotency journals and ledger invariants), callback forgery (signed webhooks, mutual TLS with rails), settlement-file tampering (integrity-checked ingestion, maker-checker on adjustments), insider fraud on the admin plane (least privilege, dual control on money-affecting operations, immutable audit logs), and merchant-credential theft (scoped API keys, rotation, anomaly detection). Threat models are living documents updated at each architecture change and re-validated by the penetration test.

## 7.3 Data Protection Mechanisms

Scope minimization by tokenization. PANs and account numbers are exchanged for format-preserving tokens at the edge of a dedicated, separately firewalled tokenization service; the rest of the platform (engine, ledger, dashboards, analytics) sees only tokens (TOR 3.2.8). This collapses the PCI-DSS assessment scope to a small, hardened zone.

Cryptography. TLS 1.3 for all external and internal service communication (mTLS service-to-service); AES-256 encryption at rest for databases, backups, and logs; field-level encryption for personal identifiers under Proclamation 1321/2024. Key management follows NIST SP 800-57: a documented key hierarchy with HSM-protected root and key-encryption keys (PKCS#11 HSM appliance, or certified software HSM as the approved fallback per TOR 3.2.8), automated rotation, split-knowledge ceremonies for root material, and full key-lifecycle audit.

## 7.4 Access Control

RBAC with least-privilege role design across admin and merchant planes (TOR 3.2.8), enforced at the gateway and re-checked in services; MFA mandatory for all administrative and merchant portal access; just-in-time elevated access with approval and session recording for production operations; quarterly access recertification tooling for HISAB's post-handover use. All administrative actions write to an append-only audit log surfaced in the audit viewer (TOR 3.2.9).

### Email

[contact@sydek.dev](mailto:contact@sydek.dev)

### Phone

+251 912983759  
+251 911971885  
+251 712785587

### Location

Kebede Haile Building,  
3rd Floor, Office 302,  
Dembel, Addis Ababa,  
Ethiopia

## 7.5 Perimeter and Runtime Defense

WAF with OWASP CRS tuned per endpoint; DDoS absorption at the edge plus application-layer rate limiting and load shedding (the same backpressure machinery as Section 3.6, because availability under attack is a performance problem); network segmentation per the DMZ topology in Section 3.5 with default-deny east-west policies in Kubernetes; runtime integrity via signed container images, admission control, and minimal distroless bases; centralized security telemetry into the ELK/SIEM layer with alerting runbooks.

## 7.6 Secure SDLC and Assurance

The SSDLC (TOR 3.2.8) is enforced in the pipeline, not by exhortation: mandatory peer review with security checklists; SAST and dependency/SCA scanning (SBOM-based, CVE-gated) on every merge; DAST against the staging environment nightly; secrets detection pre-commit and in CI; infrastructure-as-code scanning for misconfiguration; and OWASP Top 10 / ASVS verification embedded in the definition of done. Assurance milestones: internal vulnerability assessments at the end of each Phase 2 increment; an independent CREST/OSCP-qualified penetration test of the full platform before go-live (TOR deliverable 16) with retest of all critical/high findings; the PCI-DSS compliance roadmap with applicable controls implemented in-scope (TOR 6.3); and the INSA first-round certification evidence pack (Section 5.5). Annual pen-test and VA program procedures are handed to HISAB in the runbook library.

## 7.7 Incident Response and Resilience

We deliver and rehearse a security incident response plan integrated with the BCP/DR manual: severity taxonomy, on-call escalation, forensic evidence preservation, NBE notification obligations, and the 72-hour ECA breach-notification path under Proclamation 1321/2024. A tabletop exercise with HISAB staff is run during Phase 3, and the DR failover rehearsal (Section 8.6) doubles as evidence for both the BCP manual and the NBE on-site inspection.

### Email

[contact@sydek.dev](mailto:contact@sydek.dev)

### Phone

+251 912983759  
+251 911971885  
+251 712785587

### Location

Kebede Haile Building,  
3rd Floor, Office 302,  
Dembel, Addis Ababa,  
Ethiopia

## 8. Testing and Quality Assurance Strategy

### 8.1 Verification Philosophy

Following Sommerville's verification-and-validation framework, every requirement in the TRS carries a verification method, and the test program is the execution of that matrix. The test pyramid is enforced: thousands of fast unit tests at the base, contract and integration tests in the middle, and a thin layer of end-to-end journeys, because slow, flaky end-to-end suites are where payment-platform quality programs go to die.

### 8.2 Correctness of the Money Path

The ledger, fee computation, settlement netting, and split logic receive the highest rigor: 100% branch coverage; property-based testing that generates thousands of randomized transaction sequences and asserts invariants (debits equal credits; no balance ever created or destroyed except by fee/settlement rules; replaying the journal reproduces identical state); deterministic rounding rules tested at boundaries; and integer-minor-unit arithmetic verified against the documented fee schedule. Idempotency is tested adversarially (duplicate submissions, concurrent retries, crash-restart replays) reflecting Helland's principle that retry safety is a tested property, not an assumption.

### 8.3 Integration and Contract Testing

Each rail adapter is tested three ways: against our rail simulator (including injected failure modes: timeouts, 5xx, duplicate callbacks, out-of-order events); via consumer-driven contract tests pinned to recorded sandbox behavior, run in CI to detect partner-side drift; and in the partner's certification environment per their formal test plan (Section 6.3). The merchant sandbox (TOR 3.2.4) reuses the same simulators, so merchant integration certification exercises exactly the behavior production will exhibit.

#### Email

[contact@sydek.dev](mailto:contact@sydek.dev)

#### Phone

+251 912983759  
+251 911971885  
+251 712785587

#### Location

Kebede Haile Building,  
3rd Floor, Office 302,  
Dembel, Addis Ababa,  
Ethiopia

## 8.4 Performance and Load Testing

Performance tests (TOR deliverable 21) are designed per Gregg's methodology: defined workload models (open-loop arrival at 500 TPS sustained and burst-to-2,000 TPS ramp; closed-loop merchant-portal concurrency), realistic payload and routing mix agreed with HISAB, and latency measured with HDR histograms to avoid coordinated-omission distortion of the p95 figure. The suite includes: sustained-load runs ( $\geq 2$  hours at target TPS), stress-to-failure runs to locate the knee of the scalability curve (USL fit), soak tests ( $\geq 24$  hours) for leak and drift detection, and overload tests verifying graceful load shedding rather than latency collapse. Pass criteria are the TOR 6.2 table verbatim; results, configuration, and bottleneck analysis constitute the Load Test Report.

Run lengths are chosen for statistical power, not convenience: a 2-hour sustained run at 500 TPS yields 3.6 million latency samples, so the p95 estimate rests on 180,000 tail observations and even p99.9 on 3,600, which is enough to assert the 200 ms budget rather than eyeball it. HDR histograms record the full distribution at fixed precision, so percentiles are computed from recorded values, never extrapolated from means and never distorted by coordinated omission.

## 8.5 Security Testing

As Section 7.6: SAST/DAST/SCA gates in CI, ASVS-based verification in the definition of done, internal vulnerability assessments per increment, and the independent pre-go-live penetration test with full retest. Fraud-engine efficacy is tested with labeled scenario suites (velocity abuse, structuring, account-takeover patterns) measuring detection and false-positive rates against thresholds agreed with HISAB's risk team.

## 8.6 Resilience, DR, and Operational Acceptance

Before go-live we execute, with HISAB observing: multi-zone failover under load; database failover with zero-loss verification against the journal; Kafka broker loss and consumer-lag recovery; rail-outage game days proving circuit breakers, fallback routing, and PENDING\_CONFIRMATION resolution behave as designed (Nygard's patterns, verified rather than asserted); and a full backup-restore rehearsal demonstrating RPO < 1 hour / RTO < 4 hours. SRE-style runbooks, SLIs/SLOs, and alert thresholds (Beyer et al.) are validated during these exercises and delivered as TOR deliverable 26.

### Email

[contact@sydek.dev](mailto:contact@sydek.dev)

### Phone

+251 912983759  
+251 911971885  
+251 712785587

### Location

Kebede Haile Building,  
3rd Floor, Office 302,  
Dembel, Addis Ababa,  
Ethiopia

**Figure 15 - Disaster Recovery Timeline: RPO and RTO**

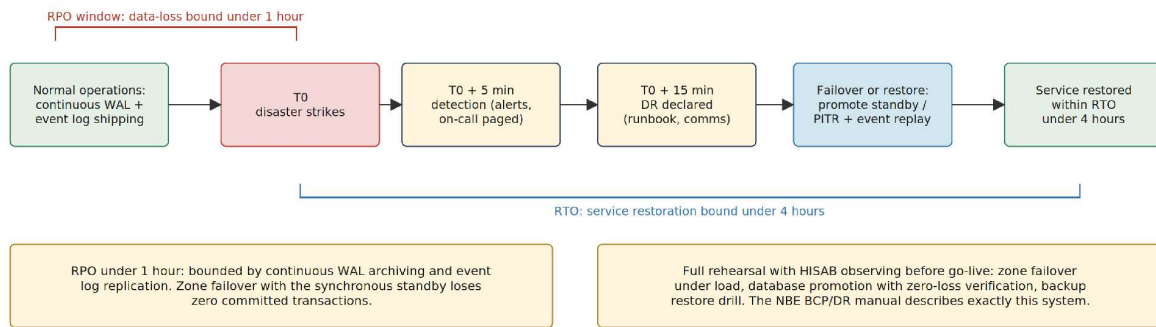


Figure 15. Disaster recovery timeline: RPO under 1 hour bounded by continuous WAL and event log shipping; RTO under 4 hours proven by pre-go-live rehearsal.

The recovery objectives are backed by arithmetic before they are backed by rehearsal. With continuous WAL shipping at  $\leq 60$ -second intervals and replication lag measured in seconds, the worst-case data-loss window is minutes against the 1-hour RPO bound, and zone failover through the synchronous standby loses zero committed transactions by definition of synchronous commit. The restore-path model  $T(\text{restore}) \approx S(\text{base})/B + T(\text{replay}) + T(\text{runbook})$  evaluates, for a 200 GB base image at 150 MB/s ( $\approx 23$  minutes), WAL replay bounded at 60 minutes, and 30 minutes of runbook execution, to  $\approx 1.9$  hours: roughly 2 $\times$  margin inside the 4-hour RTO. The pre-go-live drill then replaces the model's assumptions with measured numbers.

## 8.7 UAT and Pilot

UAT (TOR deliverable 20) executes HISAB-approved business scenarios end-to-end (onboarding through payment, settlement, reconciliation, refund, dispute, and reporting) with entry criteria (all P1/P2 defects closed, performance targets met in staging) and exit criteria (scenario pass rate, defect SLAs) agreed in the Test Plan at Phase 1. The Phase 3 pilot with 2-3 institutions runs production traffic under heightened monitoring with weekly tri-party reviews; pilot evidence is packaged to serve simultaneously as the NBE supervised-pilot demonstration (Section 5.1).

### Email

contact@sydek.dev

### Phone

+251 912983759  
+251 911971885  
+251 712785587

### Location

Kebede Haile Building,  
3rd Floor, Office 302,  
Dembel, Addis Ababa,  
Ethiopia

## 9. Project Plan and Timeline

The plan below maps our delivery to the TOR's phase structure and 28 deliverables; a fully resourced Gantt chart will be submitted within 10 working days of contract award per TOR Section 5. Bars below are summarized by month (M1-M12).

### 9.1 Phase Plan

| Phase                     | Months | Track A (Regulatory)                                                                       | Track B (Technical)                                                                                                                                                                                                                                                                            | Milestone Gate                                                            |
|---------------------------|--------|--------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------|
| 1. Discovery & Foundation | M1-M2  | Regulatory roadmap (D1); NBE dossier & six manuals (D2-D5); submission readiness           | Discovery workshops; SADD (D8) & TRS (D9) baselined; environments & CI/CD up; rail discovery opened; data protection package (D5)                                                                                                                                                              | M1: contract + project plan. M2: NBE application submitted; SADD approved |
| 2. Core Development       | M3-M5  | NBE query management; reporting templates & compliance calendar (D6); INSA gap remediation | Core engine (D10, M3); rail integrations certified in waves (D11); merchant onboarding (D12); API layer & developer portal (D13); settlement & reconciliation (D14); risk/fraud (D15); security pen test (D16); dashboards (D17); notifications & reporting (D18); infra/DevOps complete (D19) | M3: engine + AML/CFT framework. M4: rails live + onboarding live          |

#### Email

[contact@sydek.dev](mailto:contact@sydek.dev)

#### Phone

+251 912983759  
+251 911971885  
+251 712785587

#### Location

Kebede Haile Building,  
3rd Floor, Office 302,  
Dembel, Addis Ababa,  
Ethiopia

| Phase                       | Months | Track A (Regulatory)                                                                        | Track B (Technical)                                                                                                                                            | Milestone Gate                                          |
|-----------------------------|--------|---------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------|
| 3. Testing & Pilot          | M6-M8  | NBE pilot demonstration & on-site inspection support; license issuance follow-through (D7)* | UAT (D20); load & resilience testing (D21); pilot with 2-3 institutions (D22); production go-live (D23)                                                        | M5: UAT + security certification. M6: go-live + license |
| 4. Handover & Stabilization | M9-M12 | First regulatory reporting cycle shepherded; compliance calendar live                       | Source code transfer (D24); documentation suite (D25); runbooks/SOPs (D26); training & knowledge transfer (D27); 90-day stabilization with SLAed support (D28) | M7: handover complete                                   |

- **License issuance timing rests with NBE per the TOR note; our commitment is a complete, query-responsive application from Month 2 and full pilot/inspection readiness from Month 6, which positions issuance within the Phase 3 window on standard processing timelines.**

## 9.2 Critical Path and Scheduling Logic

Critical path: NBE dossier submission (M2) → EthSwitch/Telebirr certification (M3-M4) → settlement engine live (M5) → UAT + pen test (M6) → pilot (M7) → NBE inspection + go-live (M8). Float is preserved by the wave-based rail sequencing (Section 6.2) and the quorum go-live design (Section 6.4).

Dependencies on HISAB (per TOR Section 12) are scheduled explicitly: partner introductions in M1, 5-working-day deliverable review SLA, pilot-institution selection by end of M5. The weekly working group tracks these as first-class plan items.

### Email

[contact@sydek.dev](mailto:contact@sydek.dev)

### Phone

+251 912983759  
+251 911971885  
+251 712785587

### Location

Kebede Haile Building,  
3rd Floor, Office 302,  
Dembel, Addis Ababa,  
Ethiopia



[sydek.dev](https://sydek.dev)

Progress control: weekly written status, monthly milestone/financial/risk reporting, and phase-gate reviews with documented entry/exit criteria, per TOR Section 13.



**Email**

[contact@sydek.dev](mailto:contact@sydek.dev)

**Phone**

+251 912983759  
+251 911971885  
+251 712785587

**Location**

Kebede Haile Building,  
3rd Floor, Office 302,  
Dembel, Addis Ababa,  
Ethiopia

## 10. Risk Register

Top program risks with mitigations; the full register is maintained live in the program RAID log and reported monthly (TOR 13.3). Scoring: probability × impact, High/Medium/Low.

| #  | Risk                                                                               | P/I | Mitigation & Contingency                                                                                                                                                        |
|----|------------------------------------------------------------------------------------|-----|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| R1 | NBE license processing extends beyond Phase 3 window                               | M/H | Complete, checklist-verified dossier at M2; 5-day query SLA; pilot packaged as NBE demonstration; go-live plan tolerates license-gated soft launch sequencing agreed with HISAB |
| R2 | EthSwitch certification slot or interoperability delays                            | M/H | Engagement opened M1; conformance against simulator before slot; quorum go-live on remaining mandatory rails; escalation via Steering Committee and HISAB introductions         |
| R3 | Partner sandbox instability or undocumented API behavior (Telebirr/CBE Birr/banks) | H/M | Rail simulators decouple development; contract tests detect drift; adapter isolation contains blast radius; per-rail buffer in wave plan                                        |
| R4 | Commercial/settlement account negotiations with rails lag technical readiness      | M/M | Commercial track started M1 in parallel with technical discovery; HISAB-led introductions; routing supports incremental rail activation post-go-live                            |
| R5 | HSM procurement/import lead time into Ethiopia                                     | M/M | Order placed in Phase 1; certified software-HSM fallback architected per TOR 3.2.8; key ceremony plan supports later migration to hardware HSM                                  |
| R6 | Data-residency-compliant hosting falls short on capacity or reliability            | M/H | Phase 1 hosting evaluation with load-validated selection; multi-zone design; provider-portable IaC keeps switching cost low                                                     |
| R7 | Performance targets missed under realistic mix                                     | L/H | Capacity model from M1; performance tests from first increment, not at the end; latency budget per component; stress-to-failure analysis locates bottlenecks early (Gregg)      |

### Email

contact@sydek.dev

### Phone

+251 912983759  
+251 911971885  
+251 712785587

### Location

Kebede Haile Building,  
3rd Floor, Office 302,  
Dembel, Addis Ababa,  
Ethiopia

| #   | Risk                                                          | P/I | Mitigation & Contingency                                                                                                                |
|-----|---------------------------------------------------------------|-----|-----------------------------------------------------------------------------------------------------------------------------------------|
| R8  | Scope creep beyond TOR baseline erodes timeline               | M/M | Baselined SADD/TRS with formal change control; impact-assessed change requests via Steering Committee                                   |
| R9  | Key personnel attrition                                       | L/M | Named deputies for all key roles; documentation-as-you-go; knowledge transfer is continuous (Section 11), not a Phase 4 event           |
| R10 | Security finding (pen test/INSA) late in Phase 3              | M/H | Shift-left SSDLC gates from first commit; internal VA each increment; pen test scheduled M5-M6 with retest buffer before go-live        |
| R11 | Pilot institutions not operationally ready                    | M/M | Selection by end M5 with readiness checklist; onboarding support team assigned; third pilot candidate held in reserve                   |
| R12 | Regulatory change mid-engagement (new/amended NBE directives) | M/M | Quarterly regulatory watch as Track A deliverable; modular policy manuals; compliance items architected as configuration where feasible |

#### Email

[contact@sydek.dev](mailto:contact@sydek.dev)

#### Phone

+251 912983759  
+251 911971885  
+251 712785587

#### Location

Kebede Haile Building,  
3rd Floor, Office 302,  
Dembel, Addis Ababa,  
Ethiopia

    
[sydek.dev](https://sydek.dev)

## 11. Team Structure

The proposed organization meets or exceeds every key-personnel requirement of TOR

| Role                                  | Allocation                  |
|---------------------------------------|-----------------------------|
| Engagement Director / Project Manager | Full-time (overlapped role) |
| Payment Systems Architect             | Full-time (overlapped role) |
| Regulatory & Compliance Lead          | Full-time Ph.1-3            |
| AML/CFT Specialist                    | Part-time, peaks Ph.1       |
| Backend Engineers                     | Full-time Ph.2-3            |
| Frontend Engineers                    | Full-time Ph.2-3            |
| Security Engineer                     | Full-time (overlapped role) |
| DevOps / Infrastructure Lead          | Full-time (overlapped role) |
| QA / Testing Lead                     | Full-time (overlapped role) |
| Business Analyst / Trainer            | Full-time Ph.1, 3-4         |

Knowledge transfer to HISAB is structural, not terminal: HISAB engineers are invited into the working group from Phase 2, paired on operational duties during Phase 3, and certified through the formal training program (TOR deliverable 27) covering platform operation, incident response, release management, compliance reporting, and codebase orientation, so the 90-day stabilization period is a supervised handover, not a cliff.

### Email

contact@sydek.dev

### Phone

+251 912983759  
+251 911971885  
+251 712785587

### Location

Kebede Haile Building,  
3rd Floor, Office 302,  
Dembel, Addis Ababa,  
Ethiopia

## 12. Engineering and Regulatory References

The methodology in this proposal is grounded in the following canonical engineering literature and applicable Ethiopian legal instruments.

### 12.1 Engineering Literature

1. M. Kleppmann, Designing Data-Intensive Applications: The Big Ideas Behind Reliable, Scalable, and Maintainable Systems. O'Reilly Media, 2017.
2. I. Sommerville, Software Engineering, 10th ed. Pearson, 2016.
3. R. Anderson, Security Engineering: A Guide to Building Dependable Distributed Systems, 3rd ed. Wiley, 2020.
4. B. Gregg, Systems Performance: Enterprise and the Cloud, 2nd ed. Addison-Wesley, 2020.
5. M. T. Nygard, Release It! Design and Deploy Production-Ready Software, 2nd ed. Pragmatic Bookshelf, 2018.
6. B. Beyer, C. Jones, J. Petoff, and N. R. Murphy (eds.), Site Reliability Engineering: How Google Runs Production Systems. O'Reilly Media, 2016.
7. S. Newman, Building Microservices: Designing Fine-Grained Systems, 2nd ed. O'Reilly Media, 2021.
8. G. Hohpe and B. Woolf, Enterprise Integration Patterns: Designing, Building, and Deploying Messaging Solutions. Addison-Wesley, 2003.
9. E. Evans, Domain-Driven Design: Tackling Complexity in the Heart of Software. Addison-Wesley, 2003.
10. N. Forsgren, J. Humble, and G. Kim, Accelerate: The Science of Lean Software and DevOps. IT Revolution Press, 2018.
11. P. Helland, "Idempotence Is Not a Medical Condition," ACM Queue, vol. 10, no. 4, 2012.
12. C. Coye Benson, S. Loftesness, and R. Jones, Payments Systems in the U.S., 3rd ed. Glenbrook Partners, 2017.

#### Email

[contact@sydek.dev](mailto:contact@sydek.dev)

#### Phone

+251 912983759  
+251 911971885  
+251 712785587

#### Location

Kebede Haile Building,  
3rd Floor, Office 302,  
Dembel, Addis Ababa,  
Ethiopia

## 12.2 Standards

1. PCI Security Standards Council, Payment Card Industry Data Security Standard (PCI DSS) v4.0.1, 2024.
2. ISO/IEC 27001:2022, Information Security Management Systems, Requirements.
3. OWASP Application Security Verification Standard (ASVS) 4.0; OWASP Top 10 (2021).
4. NIST SP 800-57, Recommendation for Key Management.
5. FATF, International Standards on Combating Money Laundering and the Financing of Terrorism & Proliferation (FATF Recommendations), as updated.
6. ISO 20022, Universal Financial Industry Message Scheme.

## 12.3 Ethiopian Legal and Regulatory Instruments

1. National Payment System Proclamation No. 718/2011, as amended by Proclamation No. 1282/2023.
2. NBE, Licensing and Authorization of Payment System Operators Directive No. ONPS/02/2020, as amended (including Directive No. ONPS/04/2021).
3. Personal Data Protection Proclamation No. 1321/2024 (supervisory authority: Ethiopian Communications Authority).
4. Commercial Code of Ethiopia, Proclamation No. 1243/2021.
5. Applicable INSA cybersecurity audit and certification requirements; Ethiopian AML/CFT legal framework and Financial Intelligence Service reporting obligations.
6. Note: directive and proclamation citations reflect instruments in force as identified at proposal preparation; the Phase 1 Regulatory Roadmap will confirm the current consolidated versions with NBE. And for current technical specs, they are subject to change after initial scoping.

---

- End of Technical Proposal, Volume 1 -

### Email

[contact@sydek.dev](mailto:contact@sydek.dev)

### Phone

+251 912983759  
+251 911971885  
+251 712785587

### Location

Kebede Haile Building,  
3rd Floor, Office 302,  
Dembel, Addis Ababa,  
Ethiopia

    
[sydek.dev](https://sydek.dev)